



UNIVERSIDAD DE LAS FUERZAS ARMADAS - ESPE
DEPARTAMENTO DE CIENCIAS DE LA COMPUTACIÓN
Ingeniería de la Seguridad del Software

Integrantes: Mateo Sosa

NRC: 30808

Fecha: April 17, 2026

Contents

Objetivos de Aprendizaje	2
Topología del experimento	2
Marco Teórico	2
Desarrollo	2
Prerequisitos	3
Verificar Conectividad	4
Iniciar Captura en Wireshark	5
HTTP	6
HTTPS	7
Comparación	7
Conclusiones	8

Objetivos de Aprendizaje

Al finalizar esta práctica, usted será capaz de:

- Comprender las diferencias entre los protocolos HTTP y HTTPS en términos de seguridad.
- Capturar y analizar tráfico de red utilizando Wireshark.
- Identificar información sensible transmitida en texto plano.
- Reconocer cómo el cifrado protege la confidencialidad de los datos en tránsito.
- Interpretar paquetes de red y extraer conclusiones de seguridad.

Topología del experimento

- VirtualBox o VMware
- Máquina virtual con Ubuntu 24.04.4 LTS (Noble Numbat), generará tráfico web (navegador)
- Máquina virtual con Kali Linux 2026.3, capturará y analizará el tráfico
- Wireshark instalado en Kali Linux
- Ambas máquinas en red interna conectadas vía Red NAT
- Usted trabajará en un entorno controlado con dos máquinas virtuales

Marco Teórico

El protocolo HTTP (HyperText Transfer Protocol) es un protocolo de comunicación utilizado para la transferencia de información en la web. Sin embargo, transmite los datos en texto plano, lo que significa que pueden ser interceptados y leídos por terceros (Fielding et al., 1999).

Por otro lado, HTTPS (HyperText Transfer Protocol Secure) incorpora un mecanismo de cifrado mediante TLS (Transport Layer Security), el cual protege la información durante su transmisión, garantizando la confidencialidad e integridad de los datos (Rescorla, 2018).

Herramientas como Wireshark permiten capturar y analizar paquetes de red en tiempo real, lo que facilita la inspección del contenido de las comunicaciones. En conexiones HTTP, es posible visualizar credenciales y datos sensibles, mientras que en HTTPS, la información aparece cifrada e ilegible (Orebaugh et al., 2007).

Este laboratorio permite evidenciar de manera práctica cómo el cifrado contribuye a la seguridad de la información en redes.

Desarrollo

Se procederá a conectar dos máquinas virtuales entre sí. Para ello, se utilizarán las imágenes de Ubuntu LTS 24.04.4 y Kali Linux 2026.1.

El gestor de máquinas virtuales a utilizar dentro de esta práctica de laboratorio es QEMU/KVM, las cuales son nativas en Linux y proporcionan mejor rendimiento al momento de operar junto a ellas.

Prerequisitos

Para poder empezar a utilizar las máquinas virtuales, será necesario configurarlas para que puedan coexistir dentro de la misma red.

Para ello, se creará primeramente una red interna por la cual ambas podrán tener conexión a internet y, lo más importante, conexión entre ellas mismas.

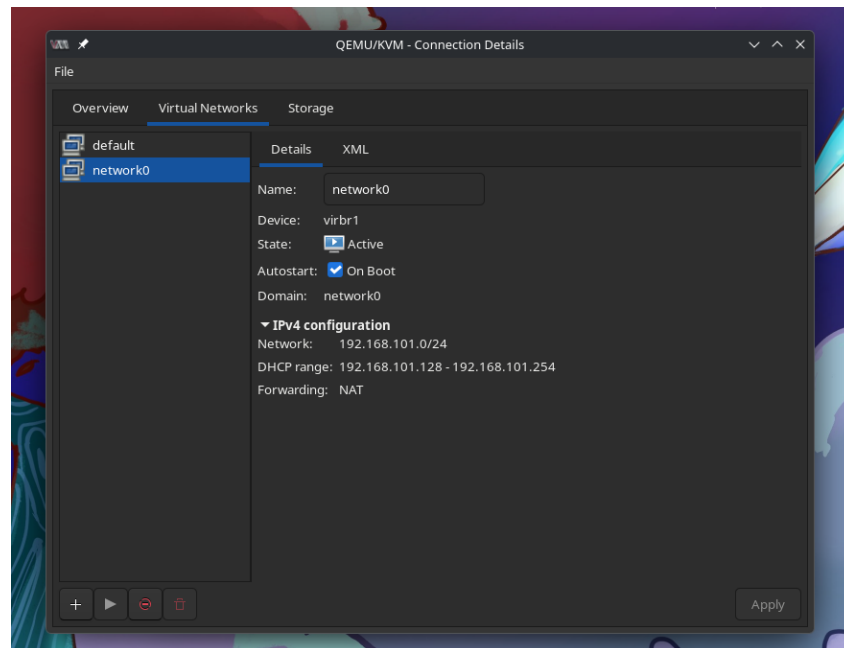


Figure 1: Generación de Red NAT

En la figura 1 se puede observar la configuración utilizada en QEMU para la red en máquinas virtuales.

Name: network0

Network: 192.168.101.0/24

Forwarding: NAT

Además de ello, se deben configurar correctamente las máquinas virtuales que se utilicen, tal como se puede ver en las figuras 2 y 3.

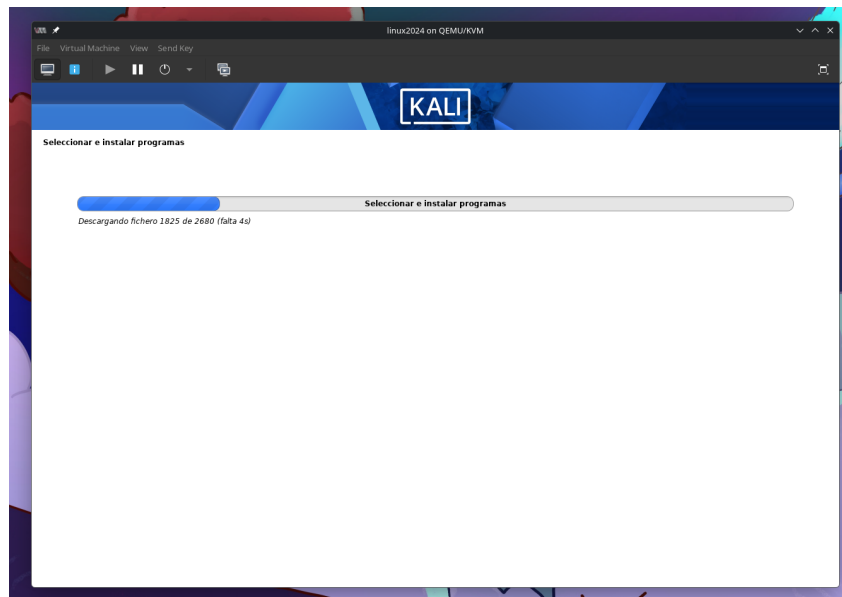


Figure 2: Instalación de Kali

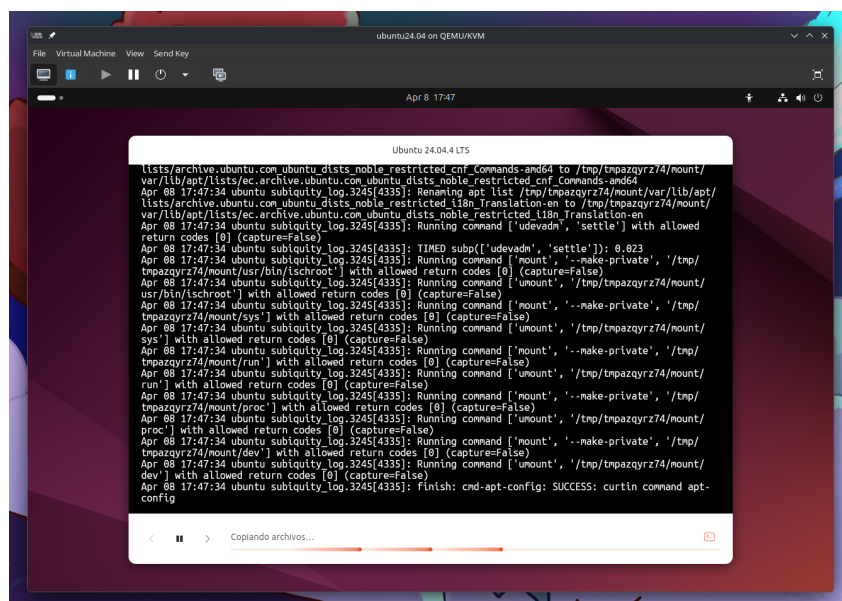


Figure 3: Instalación de Ubuntu

Verificar Conectividad

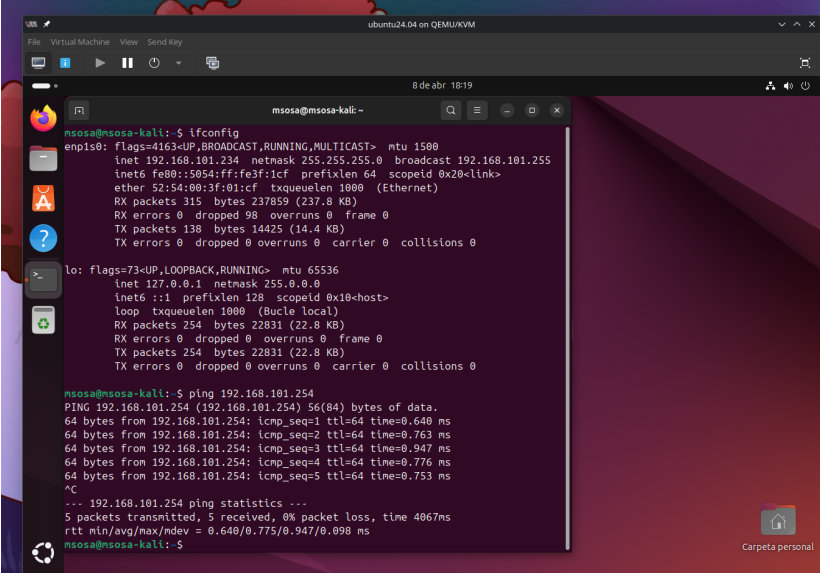
Ya que se han configurado las máquinas virtuales con sus respectivas redes, es preferible probar la conexión entre ambas para poder realizar las actividades propuestas dentro del laboratorio.

Para ello, se utilizarán dos comandos esenciales:

Para conocer la dirección asignada mediante DHCP
ifconfig

Para comprobar la conectividad
ping x.x.x.x

En las figuras 4 y 5 se pueden apreciar los comandos, con su respectiva *IP* asignada por el *DHCP* y la conectividad entre ambas.

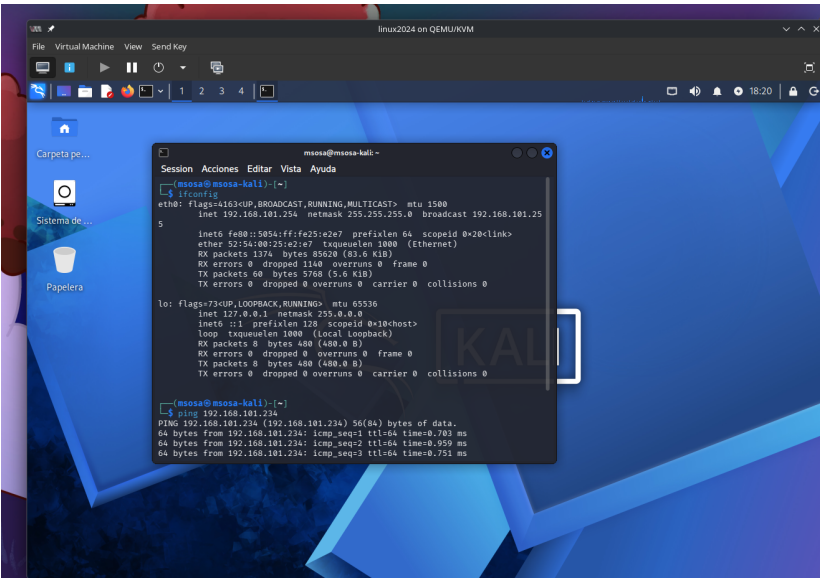


```
msosa@msosa-kali:~$ ifconfig
enp1s0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 192.168.101.234 netmask 255.255.255.0 broadcast 192.168.101.255
    inet6 fe80::5054:ff:fe3f:1cf prefixlen 64 scopeid 0x20<link>
    ether 52:54:00:3f:01:cf txqueuelen 1000 (Ethernet)
    RX packets 315 bytes 237859 (237.8 KB)
    RX errors 0 dropped 98 overruns 0 frame 0
    TX packets 138 bytes 14425 (14.4 KB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0x10<host>
    loop txqueuelen 1000 (Bucle local)
    RX packets 254 bytes 22831 (22.8 KB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 254 bytes 22831 (22.8 KB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

msosa@msosa-kali:~$ ping 192.168.101.254
PING 192.168.101.254 (192.168.101.254) 56(84) bytes of data:
64 bytes from 192.168.101.254: icmp_seq=1 ttl=64 time=0.640 ms
64 bytes from 192.168.101.254: icmp_seq=2 ttl=64 time=0.763 ms
64 bytes from 192.168.101.254: icmp_seq=3 ttl=64 time=0.947 ms
64 bytes from 192.168.101.254: icmp_seq=4 ttl=64 time=0.776 ms
64 bytes from 192.168.101.254: icmp_seq=5 ttl=64 time=0.753 ms
^C
--- 192.168.101.254 ping statistics ---
5 packets transmitted, 5 received, 0% packet loss, time 4067ms
rtt min/avg/max/ndev = 0.640/0.775/0.947/0.098 ms
msosa@msosa-kali:~$
```

Figure 4: Comando *ping* en Ubuntu



```
msosa@msosa-kali:~$ ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 192.168.101.234 netmask 255.255.255.0 broadcast 192.168.101.255
    inet6 fe80::5054:ff:fe25:e2e7 prefixlen 64 scopeid 0x20<link>
    ether 52:54:00:25:e2:e7 txqueuelen 1000 (Ethernet)
    RX packets 1374 bytes 85520 (83.0 KiB)
    RX errors 0 dropped 1140 overruns 0 frame 0
    TX packets 60 bytes 5768 (5.6 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0x10<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 8 bytes 480 (480.0 B)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 8 bytes 480 (480.0 B)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

msosa@msosa-kali:~$ ping 192.168.101.234
PING 192.168.101.234 (192.168.101.234) 56(84) bytes of data:
64 bytes from 192.168.101.234: icmp_seq=1 ttl=64 time=0.703 ms
64 bytes from 192.168.101.234: icmp_seq=2 ttl=64 time=0.959 ms
64 bytes from 192.168.101.234: icmp_seq=3 ttl=64 time=0.751 ms
```

Figure 5: Comando *ping* en Kali

Iniciar Captura en Wireshark

Para poder analizar el tráfico de la máquina de Ubuntu, es esencial usar la herramienta incluida por defecto en Kali: **Wireshark**.

Se puede acceder a la GUI de Wireshark (tal como se aprecia en la figura 6) mediante el comando:

wireshark

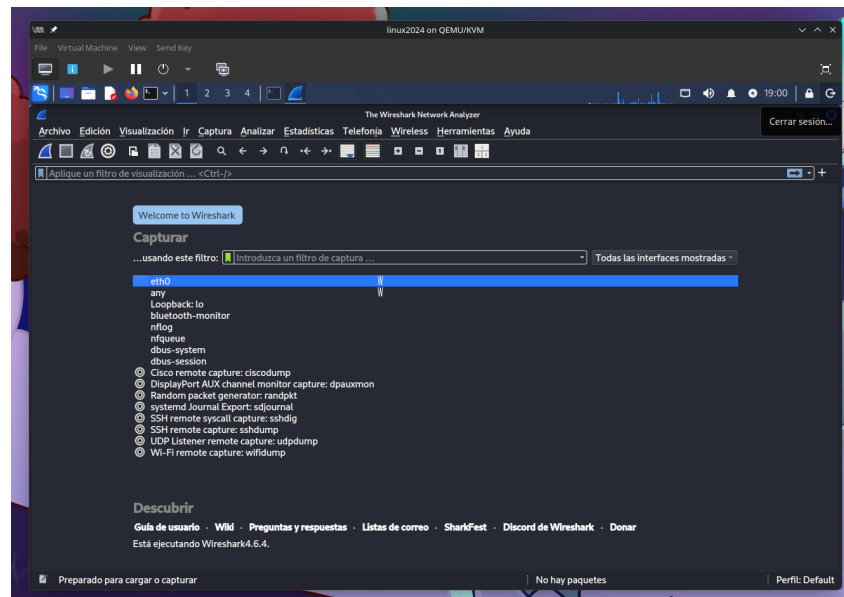


Figure 6: GUI de Wireshark

HTTP

Para poder generar tráfico HTTP, es necesario que la información pase a través de Kali para comprobarla y analizarla. Es por eso que, haciendo uso de *python* y su librería *http.server*, es posible generar un servidor HTTP para revisar datos y analizarlos.

En la figura 7 se pueden apreciar los paquetes obtenidos.

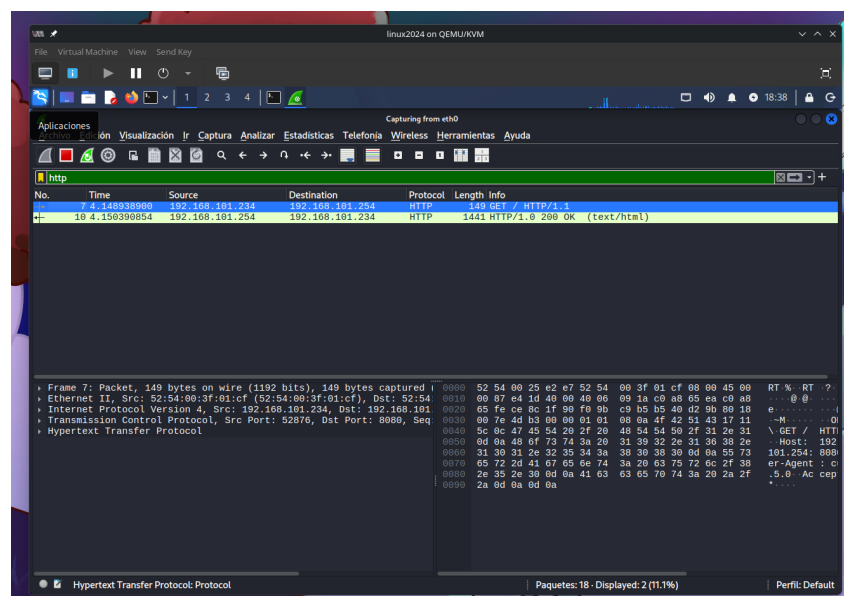


Figure 7: Tráfico HTTP en Wireshark

Los datos importantes son:

Method: GET

URL: 192.168.101.254:8080

Headers: NO

Content: plain-text

HTTPS

Para poder generar tráfico HTTPS, es necesario generar un certificado por el cual se pueda generar un servidor que permita la conexión entre Ubuntu y Kali. Para ello, usaremos openssl en el puerto 8443.

En la figura 8 se pueden apreciar los paquetes obtenidos.

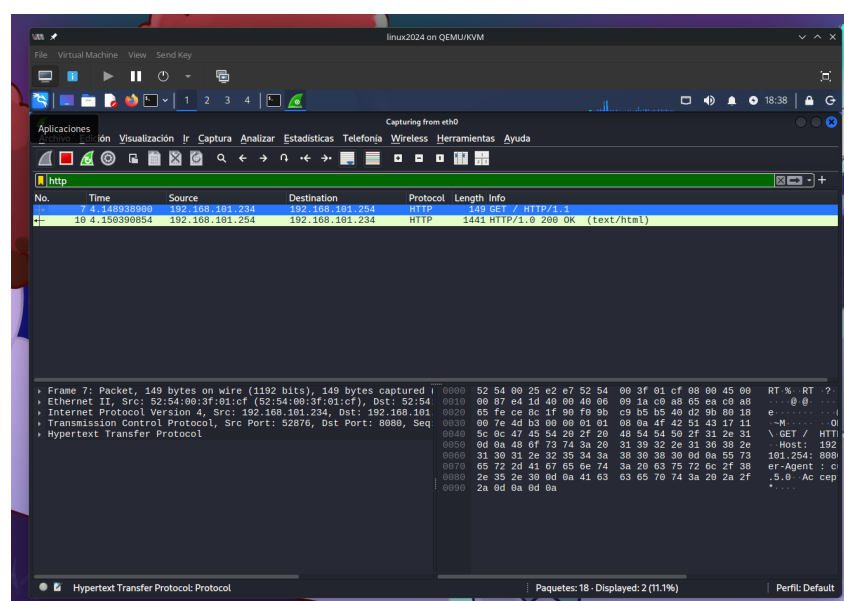


Figure 8: Tráfico HTTPS en Wireshark

Ahora, los datos que se obtienen son:

Handshake: TLS

Certificates: openssl

Content: plain-text

Comparación

Para conocer cuál de las dos es mejor, se compararán ambos protocolos dentro de una tabla.

Comparativa	HTTP	HTTPS
Visibilidad de Datos	Completa	Ninguna (Cifrado)
Nivel de Exposición	Alto	Bajo
Seguridad	Baja o Nula	Alta

Conclusiones

- HTTPS protege la confidencialidad de los datos.
- HTTP expone información sensible.
- Wireshark permite análisis pero no descifrado sin claves.



UNIVERSIDAD DE LAS FUERZAS ARMADAS - ESPE

DEPARTAMENTO DE CIENCIAS DE LA COMPUTACIÓN

Ingeniería de la Seguridad del Software

Integrantes: Mateo Sosa

NRC: 30808

Fecha: April 17, 2026

Contents

Objetivos de Aprendizaje	3
Topología del experimento	3
Marco Teórico	3
1. Operadores básicos de Google Dorks	3
Desarrollo	4
Seguridad Informática	4
Objetivo	4
Cadena de Búsqueda	4
Resultados	5
Análisis	5
Cámaras IP Indexadas	5
Objetivo	5
Cadena de Búsqueda	5
Resultados	6
Análisis	6
Login Administración	6
Objetivo	6
Cadena de Búsqueda	6
Resultados	7
Análisis	7
Credenciales en Excel	7
Objetivo	7
Cadena de Búsqueda	7
Resultados	8
Análisis	8
Archivos de Configuración	8
Objetivo	8
Cadena de Búsqueda	8
Resultados	9

Análisis	9
Archivos XLS	9
Objetivo	9
Cadena de Búsqueda	9
Resultados	10
Análisis	10
Película “Hilo Rojo”	10
Objetivo	10
Cadena de Búsqueda	10
Resultados	11
Análisis	11
Conclusiones	11

Objetivos de Aprendizaje

Al finalizar esta práctica, usted será capaz de:

- Comprender y aplicar técnicas de reconocimiento pasivo mediante operadores avanzados de búsqueda (Google Dorks).
- Identificar información potencialmente sensible expuesta en la web.
- Analizar vulnerabilidades derivadas de la exposición de información pública.
- Relacionar los hallazgos con los principios de Confidencialidad, Integridad y Disponibilidad (CIA).

Topología del experimento

- Virtualización: VirtualBox o VMware
- Máquinas virtuales:
 - Ubuntu Desktop 24.04.5 LTS (Noble Numbat) — ejecución de búsquedas y análisis
 - Kali Linux 2026.3 — apoyo en análisis de seguridad (opcional)
- Herramientas:
 - Navegador web (Firefox/Chrome)
- Red: Ambas máquinas conectadas en red NAT (entorno controlado)
- Nota: No se realizará captura ni análisis de tráfico de red en esta práctica

Marco Teórico

El reconocimiento (*Footprinting*) constituye la primera fase del *Ethical Hacking*, orientada a la recopilación de información pública sin interacción directa con los sistemas objetivo. En este contexto, los Google Dorks son operadores avanzados que permiten filtrar resultados de búsqueda y localizar información sensible expuesta, como documentos, credenciales o configuraciones inseguras.

El uso inadecuado de la publicación de información puede generar vulnerabilidades que afectan los principios de:

- Confidencialidad: Exposición de datos sensibles
- Integridad: Posible manipulación de información
- Disponibilidad: Riesgos derivados de accesos no autorizados

1. Operadores básicos de Google Dorks

Operador	Función clave	Ejemplo práctico	Otro ejemplo
<code>site:</code>	Restringe la búsqueda a un sitio específico	<code>site:example.edu</code>	<code>site:netflix.com "Caramelo"</code>
<code>filetype:</code>	Busca por tipo de archivo	<code>filetype:pdf</code> <code>inurl:confidential</code>	<code>site:netflix.com</code> <code>filetype:pdf</code>
<code>intitle:</code>	Busca palabras en el título de la página	<code>intitle:"index of"</code>	<code>site:.com</code> <code>intitle:"nomina"</code>

Operador	Función clave	Ejemplo práctico	Otro ejemplo
<code>inurl:</code>	Busca términos dentro de la URL	<code>inurl:admin</code>	<code>site:edu.ec</code> <code>inurl:login</code>
<code>intext:</code>	Encuentra palabras en el contenido	<code>intext:"password"</code>	<code>site:edu.ec</code> <code>intext:"usuario"</code>
<code>cache:</code>	Muestra versión en caché	<code>cache:example.com</code>	<code>cache:netflix.com</code>
<code>related:</code>	Encuentra sitios similares	<code>related:example.com</code>	<code>related:amazon.com</code>

Desarrollo

En el presente laboratorio se pretende hacer uso de operadores avanzados conocidos formalmente como **Google Dorks** para filtrar resultados de búsqueda e identificar información sensible expuesta.

Seguridad Informática

Objetivo

Encuentre archivos PDF sobre seguridad informática en el dominio *edu.ec*.

Cadena de Búsqueda

`site:edu.ec filetype:pdf "seguridad informática"`

Resultados

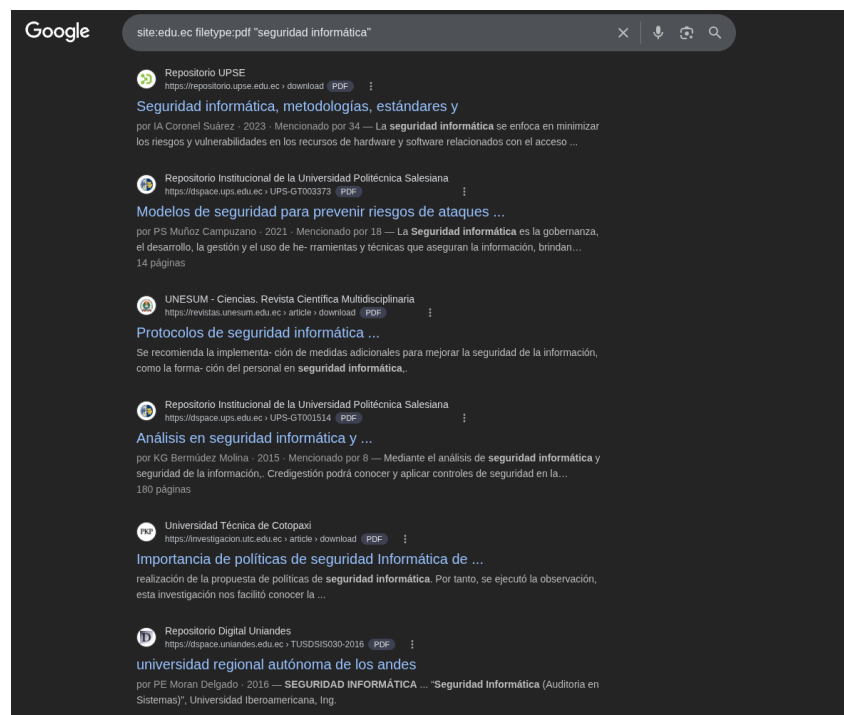


Figure 1: Resultados de Seguridad Informática

En la figura 1 se puede apreciar la búsqueda. En ella se pueden ver diversos documentos relacionados con la seguridad informática dentro de las páginas con *.edu.ec*.

Análisis

Tipo Información Identificada	Riesgo de Seguridad	Principios Triada CID	Medida de Mitigación
PDF	Bajo, todos los documentos proporcionados están públicos, generalmente proporcionados por universidades	Disponibilidad	Comprobar que las páginas realmente proporcionan esta información de forma pública

Cámaras IP Indexadas

Objetivo

Identifique cámaras IP indexadas sin autenticación en línea (análisis conceptual).

Cadena de Búsqueda

intitle:"Live View / - AXIS"

Resultados

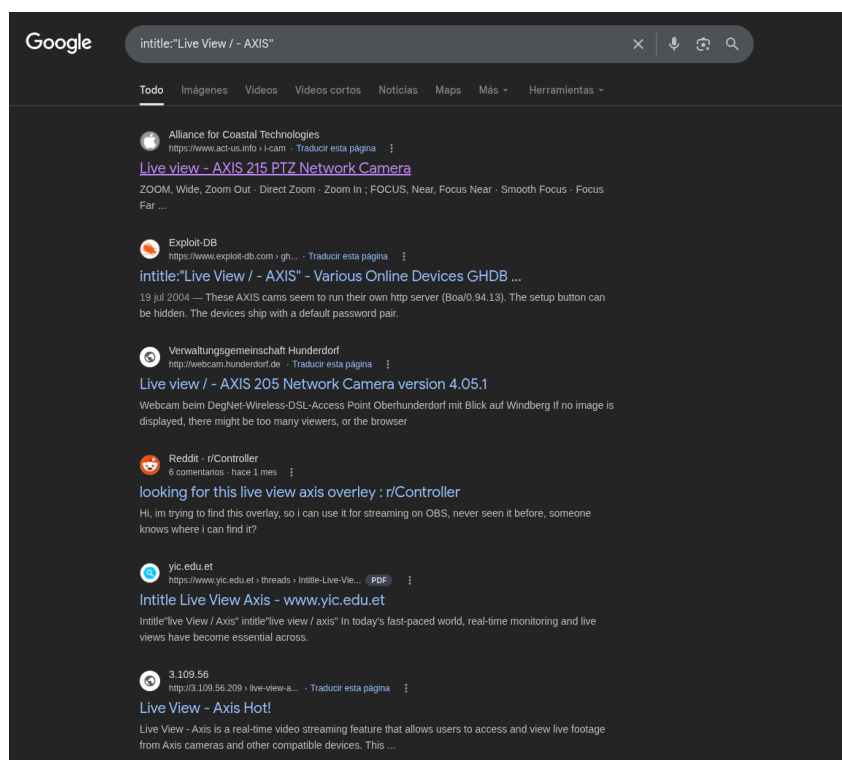


Figure 2: Resultados de Cámaras IP

En la figura 2 se pueden apreciar muchas búsquedas sobre cámaras IP identificadas y publicadas sin ninguna verificación para su revisión. Es posible apreciar incluso en algunas de ellas una dirección IP en vez de una DNS, vulnerando incluso a la propia empresa que proporciona las cámaras.

Análisis

Tipo Información Identificada	Riesgo de Seguridad	Principios Triada CID	Medida de Mitigación
Video en Tiempo Real	Alto, probablemente sean cámaras sin seguridad	Confidencialidad & Disponibilidad	Añadir accesos puntuales a estas páginas

Login Administración

Objetivo

Busque páginas de login de administración en sitios educativos de Ecuador.

Cadena de Búsqueda

site:edu.ec inurl:admin

Resultados

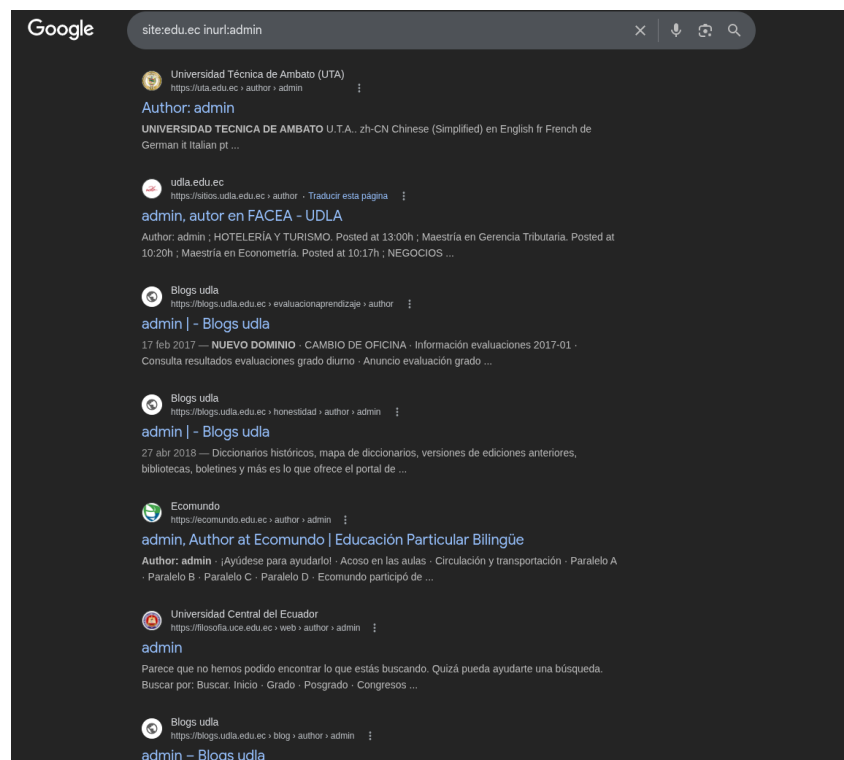


Figure 3: Resultados de Logins Administrativos

En la figura 3 se puede apreciar la vulnerabilidad de muchas páginas administrativas de universidades principalmente. Muchas de ellas ni siquiera disponen de un nombre adecuado, dando a entender que no están planeadas para ser vistas desde el buscador.

Análisis

Tipo Información Identificada	Riesgo de Seguridad	Principios Triada CID	Medida de Mitigación
Páginas Ocultas	Medio, aunque son páginas que no se planean ver, tienen la seguridad de registro	Disponibilidad	Comprobar que no existan usuarios de prueba que vulneren la seguridad

Credenciales en Excel

Objetivo

Encuentre documentos Excel con posibles credenciales en sitios corporativos.

Cadena de Búsqueda

filetype:xls OR filetype:xlsx "usuario" "contraseña"

Resultados

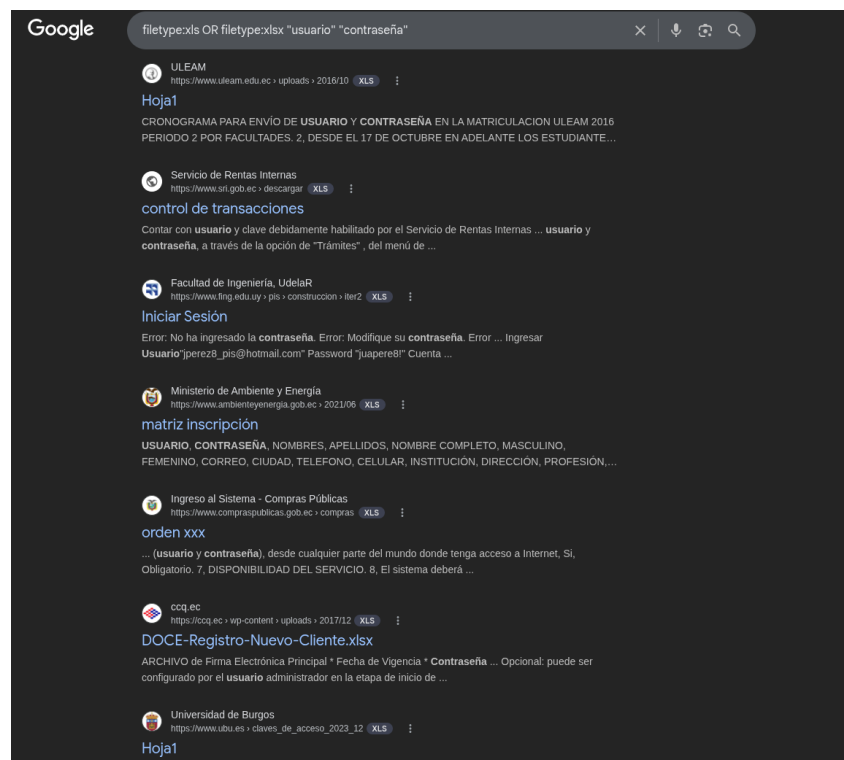


Figure 4: Resultados de Credenciales en Archivos Excel

En la figura 4 se puede apreciar que, aunque la gran mayoría de páginas redirige a cierto login, de igual forma proporcionan el archivo **xlsx** donde se guardan todos los datos. Principalmente se vulneran páginas gubernamentales.

Análisis

Tipo Información Identificada	Riesgo de Seguridad	Principios Triada CID	Medida de Mitigación
xlsx o xls	Alto, se publica información confidencial	Confidencialidad	Utilizar bases de datos seguras

Archivos de Configuración

Objetivo

Localice archivos de configuración expuestos públicamente.

Cadena de Búsqueda

filetype:env "DB_PASSWORD"

Resultados

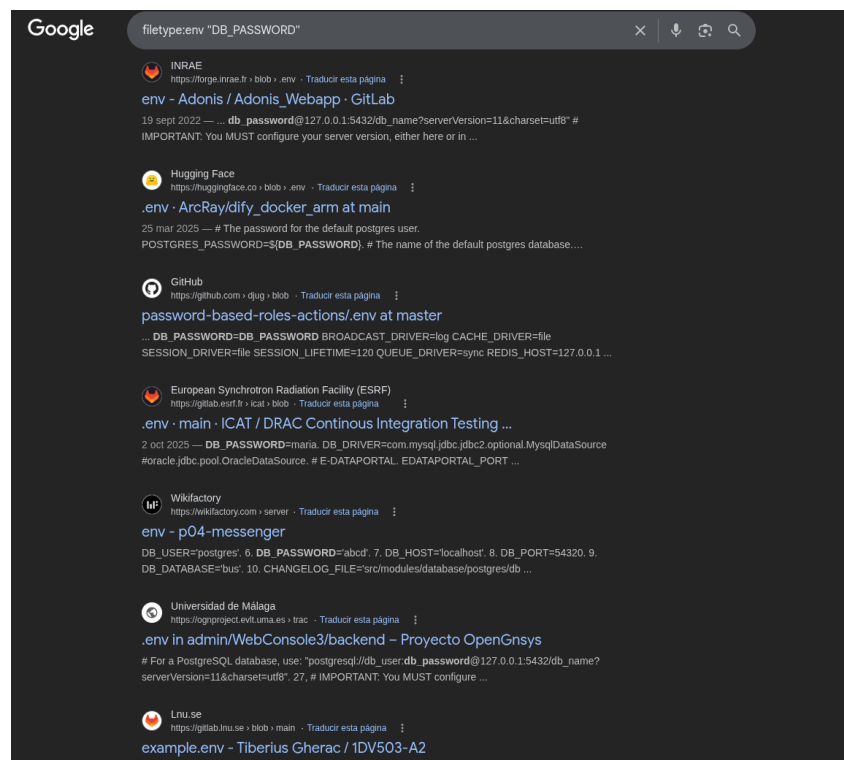


Figure 5: Resultados de Archivos de Configuración

En la figura 5 se pueden apreciar pocos resultados con archivos de configuración, pero publicando datos confidenciales de proyectos. En su gran mayoría, son proyectos pequeños y archivos subidos dentro de la plataforma de *GitHub*.

Análisis

Tipo Información Identificada	Riesgo de Seguridad	Principios Triada CID	Medida de Mitigación
.env	Medio, aunque no siempre, muchas veces se encuentran contraseñas de bases de datos en estos archivos	Confidencialidad	Mayor seguridad dentro de entornos de desarrollo

Archivos XLS

Objetivo

Encuentre archivos XLS relacionados con nómina o roles de pago.

Cadena de Búsqueda

filetype:xlsx "rol de pagos"

Resultados

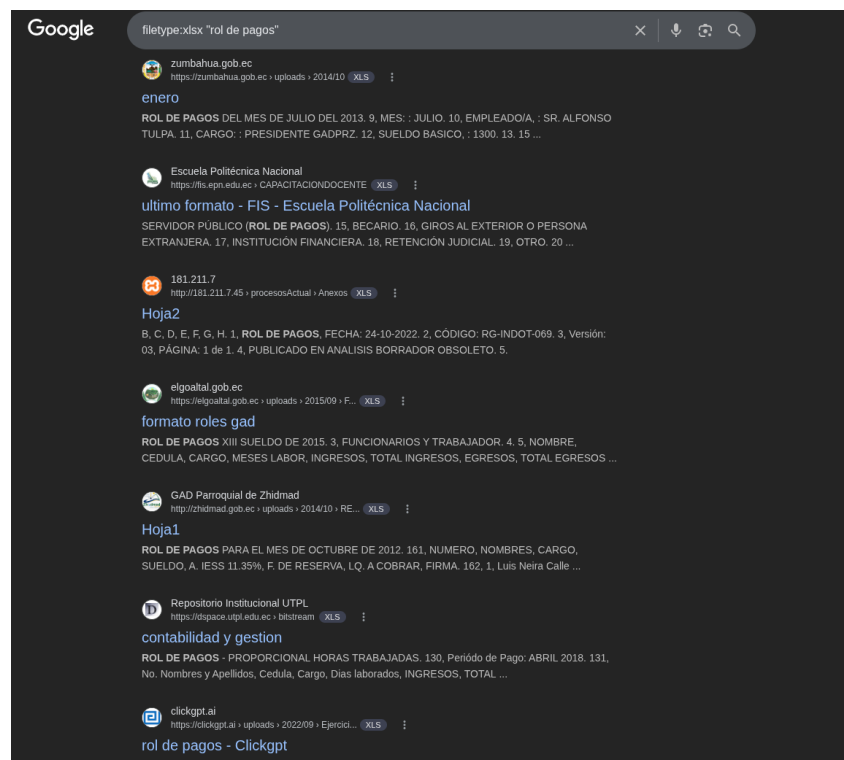


Figure 6: Resultados de Roles de Pagos

En la figura 6 se pueden apreciar muchas compañías cuyos roles de pagos están expuestos públicamente.

Análisis

Tipo Información Identificada	Riesgo de Seguridad	Principios Triada CID	Medida de Mitigación
xlsx	Medio, se vulnera información confidencial	Confidencialidad	Añadir protección a estos datos o enviarlos por un medio más seguro, como correo

Película “Hilo Rojo”

Objetivo

Busque una película en Netflix llamada “Hilo rojo” utilizando operadores.

Cadena de Búsqueda

site:netflix.com "Hilo rojo"

Resultados

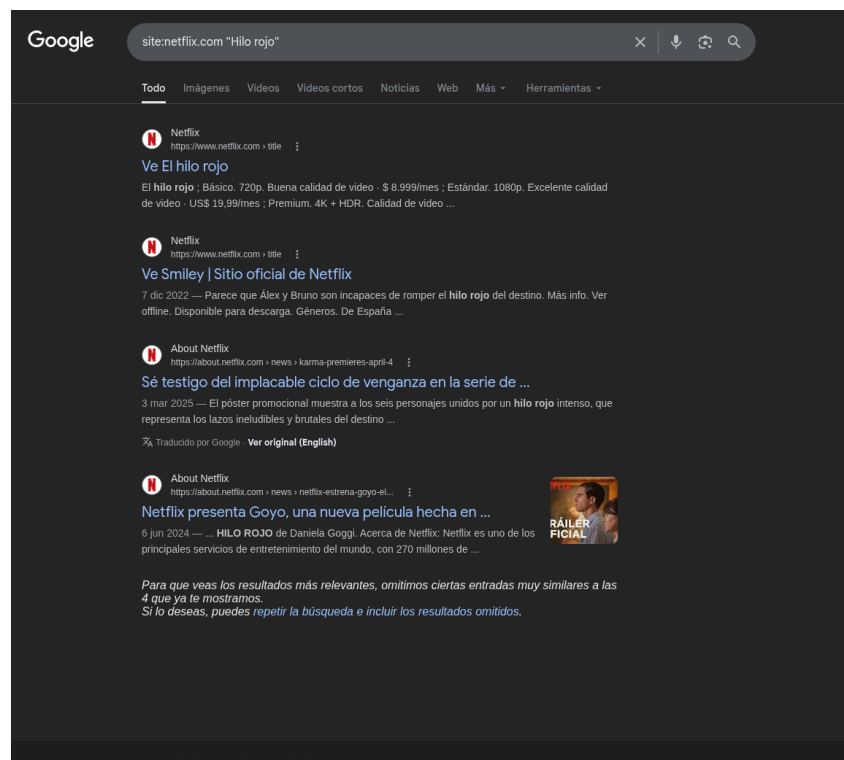


Figure 7: Resultados de Película “Hilo Rojo”

En la figura 7 se pueden apreciar pocos resultados pero todos enfocados a la película “Hilo Rojo” o relacionados.

Análisis

Tipo Información Identificada	Riesgo de Seguridad	Principios Triada CID	Medida de Mitigación
Película	Bajo, la película mantiene seguridad de Login de Netflix	Integridad	Mantener la película en el formato propuesto

Conclusiones

- El reconocimiento pasivo permite identificar vulnerabilidades sin interactuar directamente con los sistemas.
- La exposición de información pública puede representar un riesgo significativo para organizaciones.
- La aplicación de buenas prácticas de seguridad reduce la superficie de ataque.



UNIVERSIDAD DE LAS FUERZAS ARMADAS - ESPE

DEPARTAMENTO DE CIENCIAS DE LA COMPUTACIÓN

Ingeniería de la Seguridad del Software

Integrantes: Mateo Sosa

NRC: 30808

Fecha: April 30, 2026

Contents

Objetivos de Aprendizaje	3
Topología del experimento	3
Marco Teórico	3
Tipos de registro	4
Subdominios y riesgos de seguridad	5
Desarrollo	5
Análisis de DNS y Registrantes	5
Registrante y Servidores	5
Registros DNS	6
nslookup	7
host	8
Enumeración de Subdominios y Análisis del Dominio	8
Enumeración Local	8
Validación Rápida	9
DNSDumpster	9
WhoIs Domain Tools	10
Tabla	10
Verificación Pasiva	11
Conclusiones	11
Recomendaciones	11

List of Figures

1	Datos Obtenidos de whois	6
2	Datos Obtenidos de dig	6
3	Datos Obtenidos de nslookup	8
4	Datos Obtenidos de host	8

5	Validación rápida usando host	9
6	Mapa de Información de <i>example.com</i>	9
7	Información de <i>example.com</i> desde <i>WhoIs</i>	10
8	Verificación Pasiva en <i>haveibeenpwned.com</i>	11

Objetivos de Aprendizaje

Al finalizar esta práctica, usted será capaz de:

- Comprender y aplicar técnicas de reconocimiento pasivo mediante herramientas OSINT (Open Source Intelligence) y comandos en entornos Linux, como fase inicial del Ethical Hacking.
- Identificar y analizar información pública y potencialmente sensible (DNS, subdominios, direcciones IP y registrantes), evaluando posibles vulnerabilidades asociadas a su exposición.
- Verificar brechas de información utilizando fuentes abiertas y legales, interpretando los hallazgos en el contexto de la seguridad de la información.
- Elaborar informes técnicos con hallazgos y recomendaciones, relacionando los resultados con los principios de Confidencialidad, Integridad y Disponibilidad (CIA).

Topología del experimento

- Virtualización: VirtualBox o VMware
- Máquinas virtuales:
 - Ubuntu Desktop 24.04.5 LTS (Noble Numbat) — ejecución de búsquedas y análisis
 - Kali Linux 2026.3 — apoyo en análisis de seguridad (opcional)
- Herramientas:
 - Navegador web (Firefox/Chrome)
- Red: Ambas máquinas conectadas en red NAT (entorno controlado)

Marco Teórico

El reconocimiento (Footprinting) constituye la primera fase del Ethical Hacking, orientada a la recopilación de información pública sin interacción directa con los sistemas objetivo (OWASP, 2024). Su finalidad es conocer la superficie de exposición digital de una organización, identificando posibles puntos de riesgo.

El reconocimiento pasivo se apoya en herramientas OSINT (Open Source Intelligence) que extraen información de registros DNS, WHOIS, subdominios, direcciones IP y brechas públicas, respetando siempre la ley y la ética profesional.

El OSINT es el proceso de recolección y análisis de información proveniente de fuentes públicas disponibles en Internet. En ciberseguridad, se utiliza en la fase de reconocimiento pasivo para identificar infraestructura, servicios y posibles exposiciones sin interactuar directamente con sistemas internos.

Herramienta/comando	Tipo	Descripción	Ejemplos
Whois	CLI	Consulta información del registrante, fechas y servidores de nombres	<code>whois google.com / whois espe.edu.ec</code>

Herramienta/comando	Tipo	Descripción	Ejemplos
Dig	CLI	Extrae registros DNS (A, MX, TXT, NS, etc.)	<code>dig google.com / dig google.com MX</code>
Nslookup	CLI	Permite resolver registros específicos	<code>nslookup google.com / nslookup -type=MX gmail.com</code>
Host	CLI	Muestra registros DNS de manera simple y rápida	<code>host google.com / host -t ns facebook.com</code>
dnsenum / dnsrecon	CLI	Enumeran subdominios y registros DNS asociados	<code>dnsenum google.com / dnsrecon -d example.com</code>
Whois Domain Tools	Web	Muestra información histórica y pública del dominio	Buscar: <code>google.com / amazon.com</code>
DNSDumpster	Web	Visualiza la infraestructura y subdominios públicos	Buscar: <code>microsoft.com / yahoo.com</code>
Have I Been Pwned	Web	Verifica exposición en brechas públicas	Buscar: <code>test@gmail.com / example.com</code>

Tipos de registro

Dig: herramienta de línea de comandos en Linux utilizada para consultar información DNS. Permite obtener registros A, MX, TXT y NS.

Nslookup: permite consultar servidores DNS y obtener información asociada a dominios.

Host: herramienta simple para consultar registros DNS de forma rápida.

Tipo de registro	Descripción	Comando en dig	Comando en nslookup	Comando en host
A	Dirección IP del dominio	<code>dig google.com A</code>	<code>nslookup -type=A google.com</code>	<code>host -t A google.com</code>
MX	Servidores de correo	<code>dig google.com MX</code>	<code>nslookup -type=MX google.com</code>	<code>host -t MX google.com</code>

Tipo de registro	Descripción	Comando en dig	Comando en nslookup	Comando en host
TXT	Información de verificación (SPF, DKIM, etc.)	dig google.com TXT	nslookup -type=TXT google.com	host -t TXT google.com
NS	Servidores de nombres	dig google.com NS	nslookup -type=NS google.com	host -t NS google.com

Nota: SPF y DKIM ayudan a evitar suplantación de identidad y se publican como registros TXT.

Subdominios y riesgos de seguridad

En el reconocimiento pasivo es común identificar subdominios asociados a un dominio principal.

Subdominios frecuentes:

- dev: entornos de desarrollo
- test: sistemas de prueba
- api: servicios backend
- mail: servidores de correo
- backup: sistemas de respaldo

Estos pueden representar riesgos si están expuestos, ya que suelen tener menor protección que entornos productivos.

Desarrollo

Análisis de DNS y Registrantes

Registrante y Servidores

whois example.com

Registrante: RESERVED-Internet Assigned Numbers Authority

Fecha-Creación: 1995-08-14T04:00:00Z

Fecha-Expiración: 2026-08-13T04:00:00Z

Servidores:

- ELLIOTT.NS.CLOUDFLARE.COM
- HERA.NS.CLOUDFLARE.COM

```
msosa@msosa-kali: ~  
Session Acciones Editar Vista Ayuda  
msosa@msosa-kali)~  
$ whois example.com  
Domain Name: EXAMPLE.COM  
Registry Domain ID: 2336799_DOMAIN_COM-VRSN  
Registrar WHOIS Server: whois.iana.org  
Registrar URL: http://res-dom.iana.org  
Updated Date: 2026-01-16T18:26:50Z  
Creation Date: 1995-08-14T04:00:00Z  
Registry Expiry Date: 2026-08-13T04:00:00Z  
Registrar: RESERVED-Internet Assigned Numbers Authority  
Registrar IANA ID: 376  
Registrar Abuse Contact Email:  
Registrar Abuse Contact Phone:  
Domain Status: clientDeleteProhibited https://icann.org/epp#clientDeleteProhibited  
Domain Status: clientTransferProhibited https://icann.org/epp#clientTransferProhibited  
Domain Status: clientUpdateProhibited https://icann.org/epp#clientUpdateProhibited  
Name Server: ELLIOTT.NS.CLOUDFLARE.COM  
Name Server: HERA.NS.CLOUDFLARE.COM  
DNSSEC: signedDelegation  
DNSSEC DS Data: 2371 13 2 C988EC423E3880EB8DD8A46FE06CA230EE23F358578D64E78B29C3E1C83D245A  
URL of the ICANN Whois Inaccuracy Complaint Form: https://www.icann.org/wicf/  
>>> Last update of whois database: 2026-04-14T15:30:06Z <<<
```

Figure 1: Datos Obtenidos de whois

Registros DNS

Addresses

```
$ dig example.com A +short  
172.66.147.243  
104.20.23.154
```

Mail Exchange

```
$ dig example.com MX +short  
0 .
```

Text

```
$ dig example.com TXT +short  
"v=spf1 -all"  
"_k2n1y4vw3qtb4skdx9e7dxt97qrmmq9"
```

Name System

```
$ dig example.com NS +short  
hera.ns.cloudflare.com.  
elliott.ns.cloudflare.com.
```

```
msosa@msosa-kali: ~  
Session Acciones Editar Vista Ayuda  
msosa@msosa-kali)~  
$ dig example.com A +short  
172.66.147.243  
104.20.23.154  
msosa@msosa-kali)~  
$ dig example.com MX +short  
0 .  
msosa@msosa-kali)~  
$ dig example.com TXT +short  
"v=spf1 -all"  
"_k2n1y4vw3qtb4skdx9e7dxt97qrmmq9"  
msosa@msosa-kali)~  
$ dig example.com NS +short  
hera.ns.cloudflare.com.  
elliott.ns.cloudflare.com.  
msosa@msosa-kali)~  
$
```

Figure 2: Datos Obtenidos de dig

nslookup

```
$ nslookup -type=mx example.com
```

```
Server:      192.168.101.1
Address:     192.168.101.1#53
```

Non-authoritative answer:

```
example.com    mail exchanger = 0 .
```

Authoritative answers can be found from:

```
$ nslookup -type=ns example.com
```

```
Server:      192.168.101.1
Address:     192.168.101.1#53
```

Non-authoritative answer:

```
example.com    nameserver = hera.ns.cloudflare.com.
example.com    nameserver = elliottns.cloudflare.com.
```

Authoritative answers can be found from:

```
hera.ns.cloudflare.com internet address = 172.64.32.162
elliottns.cloudflare.com internet address = 108.162.195.228
elliottns.cloudflare.com internet address = 172.64.35.228
elliottns.cloudflare.com internet address = 162.159.44.228
hera.ns.cloudflare.com internet address = 108.162.192.162
hera.ns.cloudflare.com internet address = 173.245.58.162
```

```
$ nslookup -type=txt example.com
```

```
Server:      192.168.101.1
Address:     192.168.101.1#53
```

Non-authoritative answer:

```
example.com    text = "_k2n1y4vw3qtb4skdx9e7dxt97qrmmq9"
example.com    text = "v=spf1 -all"
```

Authoritative answers can be found from:

```
(msosa@msosa-kali)-[~]
$ nslookup -type=mx example.com
Server:      192.168.101.1
Address:     192.168.101.1#53

Non-authoritative answer:
example.com  mail exchanger = 0 .

Authoritative answers can be found from:

(msosa@msosa-kali)-[~]
$ nslookup -type=ns example.com
Server:      192.168.101.1
Address:     192.168.101.1#53

Non-authoritative answer:
example.com  nameserver = hera.ns.cloudflare.com.
example.com  nameserver = elliottns.cloudflare.com.

Authoritative answers can be found from:
hera.ns.cloudflare.com internet address = 172.64.32.162
elliottns.cloudflare.com internet address = 108.162.195.228
elliottns.cloudflare.com internet address = 172.64.35.228
elliottns.cloudflare.com internet address = 162.159.44.228
hera.ns.cloudflare.com internet address = 108.162.192.162
hera.ns.cloudflare.com internet address = 173.245.58.162

(msosa@msosa-kali)-[~]
$ nslookup -type=txt example.com
Server:      192.168.101.1
Address:     192.168.101.1#53

Non-authoritative answer:
example.com  text = "_k2n1y4vw3qtb4skdx9e7dxt97qrmmq9"
example.com  text = "v=spf1 -all"

Authoritative answers can be found from:
```

Figure 3: Datos Obtenidos de nslookup

host

```
$ host -t ns example.com
example.com name server hera.ns.cloudflare.com.
example.com name server elliottns.cloudflare.com.

$ host -t txt example.com
example.com descriptive text "_k2n1y4vw3qtb4skdx9e7dxt97qrmmq9"
example.com descriptive text "v=spf1 -all"
```

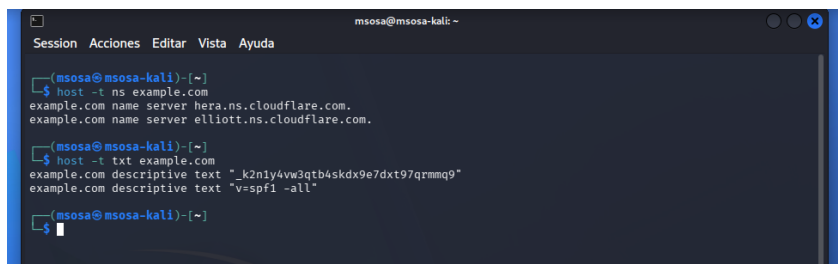


Figure 4: Datos Obtenidos de host

Enumeración de Subdominios y Análisis del Dominio

Enumeración Local

Haciendo uso de los comandos `dnsenum` y `dnsrecon -d`, se presentan una gran cantidad de dominios, pero la gran mayoría no tienen nada que ver con *dev*, *test*, *api* o *backup*.

dns.google.com.	324	IN	A	8.8.8.8
dns.google.com.	324	IN	A	8.8.4.4
elections.google.com.	134	IN	A	172.217.162.110
environment.google.com.	129	IN	A	142.251.132.174
europe.google.com.	129	IN	A	142.251.132.164

finance.google.com.	129	IN	CNAME	www3.l.google.com.
www3.l.google.com.	297	IN	A	172.217.30.206
health.google.com.	64	IN	A	172.217.28.110
issuetracker.google.com.	61	IN	A	172.217.30.206
jobs.google.com.	70	IN	CNAME	www3.l.google.com.
www3.l.google.com.	174	IN	A	172.217.30.206
mail.google.com.	181	IN	A	172.217.29.5
map.google.com.	63	IN	CNAME	maps.google.com.
maps.google.com.	180	IN	A	172.217.28.110
mobile.google.com.	63	IN	CNAME	mobile.l.google.com.

Validación Rápida

```

msosa@msosa-kali ~
Session Acciones Editar Vista Ayuda
msosa@msosa-kali)-[~]
$ host sub.example.com
Host sub.example.com not found: 3(NXDOMAIN)

msosa@msosa-kali)-[~]
$ host -t ns example.com
example.com name server elliot.ns.cloudflare.com.
example.com name server hera.ns.cloudflare.com.

msosa@msosa-kali)-[~]
$ host -t mx example.com
example.com mail is handled by 0 .

msosa@msosa-kali)-[~]
$

```

Figure 5: Validación rápida usando host

No existe ningún registro A o MX para la dirección de *example.com*. Aunque es una dirección de ejemplo, se mantiene segura.

DNSDumpster

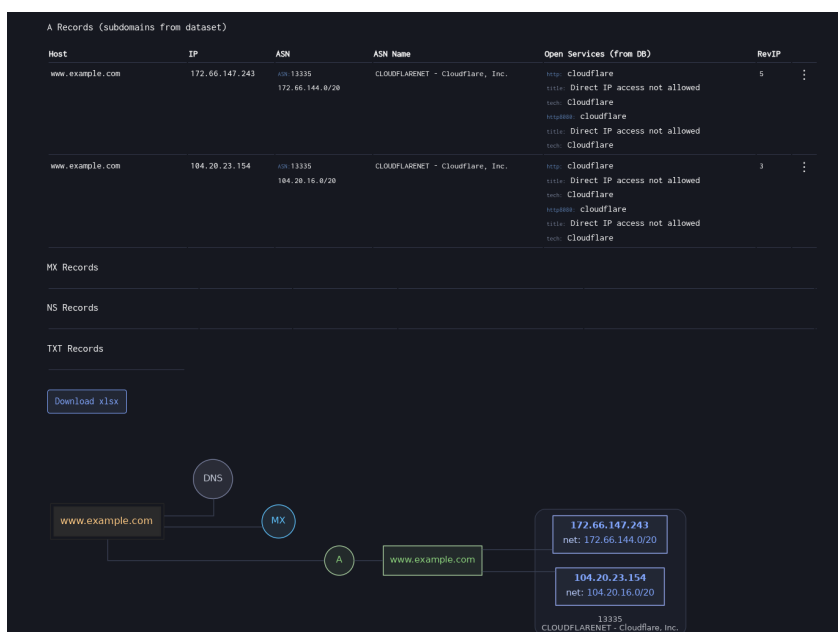


Figure 6: Mapa de Información de *example.com*

WhoIs Domain Tools

DomainTools PROFILE CONNECT MONITOR SUPPORT Whois Lookup

Home > Whois Lookup > Example.com Notice: Possible deprecation

Whois Record for Example.com

— Domain Profile

Registrar	RESERVED-Internet Assigned Numbers Authority IANA ID: — URL: http://res-dom.iana.org Whois Server: —
Registrar Status	clientDeleteProhibited, clientTransferProhibited, clientUpdateProhibited
Dates	12,522 days old Created on 1992-01-01 Expires on 2026-08-13 Updated on 2026-01-16
Name Servers	ELLIOTT.NS.CLOUDFLARE.COM (has 41,369,275 domains) HERA.NS.CLOUDFLARE.COM (has 41,369,275 domains)
IP Address	104.20.23.154 - 231 other sites hosted on this server
IP Location	🇺🇸 - Florida - Miami - Cloudflare Inc.
ASN	🇺🇸 AS13335 CLOUDFLARENET - Cloudflare, Inc., US (registered Jul 14, 2010)
Domain Status	Registered And No Website
IP History	249 changes on 249 unique IP addresses over 21 years
Hosting History	1 change on 2 unique name servers over 1 year

Whois Record (last updated on 2026-04-14)

domain:	EXAMPLE.COM
organisation:	Internet Assigned Numbers Authority
created:	1992-01-01
source:	IANA

Figure 7: Información de *example.com* desde *WhoIs*

Registrant-Organization: Internet Assigned Numbers Authority
Registrar: <http://res-dom.iana.org>
IP-Address: 104.20.23.154
Name-Servers:
- ELLIOTT.NS.CLOUDFLARE.COM
- HERA.NS.CLOUDFLARE.COM
Last-Update: 2026-01-16

Tabla

Campo	Valor Encontrado	Observación	Guía para el estudiante
Registrant Organization	Internet Assigned Numbers Authority	Organización que administra dominios de ejemplo y estándares de Internet	¿Quién es el dueño del dominio? (empresa o persona)
Registrar	IANA (res-dom.iana.org)	No es un registrador comercial típico, ya que el dominio es reservado	¿Qué empresa registró el dominio? (ej. GoDaddy, Namecheap)

Campo	Valor Encontrado	Observación	Guía para el estudiante
IP Address	104.20.23.154 / 172.66.147.243	IPs pertenecen a infraestructura de Cloudflare (CDN/proxy)	Dirección IP asociada al dominio
IP Location	Red distribuida (Cloudflare, global)	No apunta a un país específico porque usa CDN	País o ciudad donde está alojado el servidor
Name Servers	hera.ns.cloudflare.com / el-liott.ns.cloudflare.com	DNS gestionado por Cloudflare	Servidores DNS que gestionan el dominio
Last Update	2026-01-16	Última actualización registrada del dominio	Fecha de última modificación del dominio

Verificación Pasiva

Para el correo institucional (dmsosa3@espe.edu.ec), la revisión dentro de la página web en la figura 8 determinó que no existen ataques realizados a esta dirección de correo electrónico.

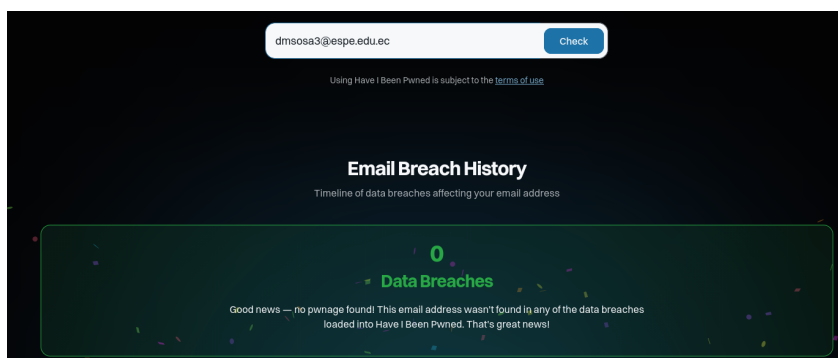


Figure 8: Verificación Pasiva en *haveibeenpwned.com*

Conclusiones

- Se aplicaron técnicas de reconocimiento pasivo utilizando herramientas como whois, dig, nslookup, host, dnsenum y dnsrecon.
- Se identificaron registros DNS A, MX, NS y TXT.
- El análisis de subdominios permitió identificar posibles superficies de ataque.
- La información pública puede revelar elementos críticos de la infraestructura.
- Herramientas como Whois Domain Tools y Have I Been Pwned amplían el análisis.

Recomendaciones

- Analizar únicamente dominios autorizados o de laboratorio.
- Interpretar correctamente los registros DNS.
- Prestar atención a subdominios sensibles como dev, test, api o backup.
- Usar herramientas de forma ética y controlada.

- Evitar divulgar información sensible.
- Aplicar principios CIA en el análisis.
- Cumplir normativa legal vigente (Arts. 232–234 del COIP).



UNIVERSIDAD DE LAS FUERZAS ARMADAS - ESPE

DEPARTAMENTO DE CIENCIAS DE LA COMPUTACIÓN

Ingeniería de la Seguridad del Software

Integrantes: Mateo Sosa

NRC: 30808

Fecha: April 30, 2026

Contents

Objetivos de Aprendizaje	2
Topología del experimento	2
Marco Teórico	2
Desarrollo	4
Reconocimiento pasivo de red local	4
Reconocimiento activo sobre objetivo público	5
Detección de sistema operativo	6
Enumeración SMB en entorno local	6
Conclusiones	7

List of Figures

1	Reconocimiento Pasivo	3
2	Reconocimiento Activo	3
3	Identificación de Hosts Activos en Red Local	4
4	Análisis de Host Público <i>ScanMe</i>	5
5	Análisis Extendido de Host Público <i>ScanMe</i>	5
6	Análisis de Información del sistema operativo de <i>ScanMe</i>	6
7	Extracción de Información con <i>enum4linux</i>	6

Objetivos de Aprendizaje

Al finalizar esta práctica, usted será capaz de:

- Diferenciar entre reconocimiento pasivo y activo
- Aplicar escaneo de red con nmap
- Analizar información de un host público controlado: `scanme.nmap.org`
- Utilizar enum4linux en un entorno local controlado
- Identificar:
 - Puertos abiertos y servicios
 - Sistema operativo aproximado
 - Usuarios, grupos y recursos compartidos
 - Evaluar riesgos de exposición de información

Topología del experimento

- Virtualización: VirtualBox o VMware
- Máquinas virtuales:
 - Ubuntu Desktop 24.04.5 LTS (Noble Numbat) — ejecución de búsquedas y análisis, objetivo local con servicios SMB habilitados
 - Kali Linux 2026.3 — apoyo en análisis de seguridad (opcional)
- Herramientas:
 - Navegador web (Firefox/Chrome)
- Red: Ambas máquinas conectadas en red NAT (entorno controlado)
- Objetivo público controlado: `scanme.nmap.org`

Marco Teórico

El reconocimiento es la fase inicial en la evaluación de seguridad de redes y sistemas, cuyo objetivo es recopilar información relevante sobre la infraestructura objetivo, como hosts activos, puertos abiertos y servicios disponibles. Esta etapa es clave para comprender la superficie de ataque y posibles vectores de riesgo (Stallings, 2018).

Se distingue entre reconocimiento pasivo y activo. El reconocimiento pasivo obtiene información sin interactuar directamente con el sistema, mientras que el activo implica interacción mediante técnicas como escaneo de puertos o identificación de servicios, lo que permite mayor precisión, aunque con mayor probabilidad de detección (Bishop, 2018).



Figure 1: Reconocimiento Pasivo

En este contexto, **Nmap** es una herramienta fundamental para el reconocimiento activo, ya que permite descubrir hosts, identificar puertos y servicios, y realizar análisis de red de forma eficiente (Nmap Project, 2024). Por otro lado, **enum4linux** se utiliza para la enumeración de sistemas que exponen servicios SMB, permitiendo obtener información como usuarios, grupos y recursos compartidos (Kali Tools, 2024).



Figure 2: Reconocimiento Activo

El uso de entornos controlados como `scanme.nmap.org` permite practicar estas técnicas de forma segura.

Table 1: Tabla de herramientas, tipo de reconocimiento y descripción.

Herramienta	Tipo de reconocimiento	Descripción	Ejemplo de uso
<code>nmap -sn</code>	Pasivo / descubrimiento	Identifica hosts activos sin escanear puertos	<code>nmap -sn 192.168.56.0/24</code>
<code>nmap -sV</code>	Activo	Detecta servicios y versiones	<code>nmap -sV scanme.nmap.org</code>
<code>nmap -O</code>	Activo	Identifica sistema operativo	<code>nmap -O scanme.nmap.org</code>
<code>nmap</code>	Activo	Escaneo general del host	<code>nmap scanme.nmap.org</code>
<code>enum4linux -a</code>	Activo (SMB)	Extrae usuarios, grupos y recursos	<code>enum4linux -a 192.168.56.20</code>
<code>smbclient -L</code>	Activo	Enumera recursos compartidos	<code>smbclient -L //192.168.56.20 -N</code>
<code>who / w</code>	Local	Muestra usuarios conectados	<code>who / w</code>
<code>host / dig</code>	Pasivo	Consulta DNS	<code>dig scanme.nmap.org</code>

Desarrollo

Reconocimiento pasivo de red local

```
(msosa@msosa-kali)-[~]
$ nmap -sn 192.168.56.0/24
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-16 10:33 -0500
Nmap done: 256 IP addresses (0 hosts up) scanned in 206.34 seconds
```

Figure 3: Identificación de Hosts Activos en Red Local

Dentro de la red local, se detectaron 254 posibles hosts, aunque ninguno activo.

La diferencia con el escaneo activo es que, en el reconocimiento pasivo únicamente se conoce qué dispositivos están conectados pasando desapercibidos, puesto que no se vulnera ningún servicio sino que se conocen sus puertos.

Reconocimiento activo sobre objetivo público

```
(msosa@msosa-kali)-[~]
$ nmap scanme.nmap.org
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-16 10:41 -0500
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.30s latency).
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2f
Not shown: 990 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
135/tcp    filtered msrpc
139/tcp    filtered netbios-ssn
445/tcp    filtered microsoft-ds
1720/tcp   open  h323q931
2000/tcp   open  cisco-sccp
3389/tcp   filtered ms-wbt-server
9929/tcp   open  nping-echo
31337/tcp  open  Elite
```

Figure 4: Análisis de Host Público *ScanMe*

Este host tiene 990 puertos cerrados, pero aquellos que mantiene abiertos son:

Table 2: Tabla de Puertos Abiertos en Página Web *ScanMe*

Puerto	Estado	Servicio
22/tcp	ABIERTO	ssh
80/tcp	ABIERTO	http
135/tcp	FILTRADO	msrpc
139/tcp	FILTRADO	netbios-ssn
445/tcp	FILTRADO	microsoft-ds
1720/tcp	ABIERTO	h323q931
2000/tcp	ABIERTO	cisco-sccp
3389/tcp	FILTRADO	ms-wbt-server
9929/tcp	ABIERTO	nping-echo
31337/tcp	ABIERTO	Elite

Además, se puede realizar un escaneo extendido:

```
(msosa@msosa-kali)-[~]
$ nmap -sV scanme.nmap.org
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-16 10:45 -0500
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.18s latency).
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2f
Not shown: 996 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
22/tcp    open  ssh            OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http           Apache httpd 2.4.7 ((Ubuntu))
9929/tcp   open  nping-echo     Nping echo
31337/tcp open  tcpwrapped
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 32.00 seconds
```

Figure 5: Análisis Extendido de Host Público *ScanMe*

Se puede observar que se tiene un sistema operativo Linux, manteniendo los siguientes servicios abiertos:

22/tcp ssh

80/tcp http
9929/tcp nping-echo
31337/tcp tcpwrapped

Detección de sistema operativo

```
(msosa@msosa-kali)-[~]
$ nmap -O scanme.nmap.org
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-16 10:53 -0500
Stats: 0:00:17 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 87.60% done; ETC: 10:53 (0:00:02 remaining)
Stats: 0:00:21 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 97.32% done; ETC: 10:53 (0:00:01 remaining)
Stats: 0:00:23 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 99.99% done; ETC: 10:53 (0:00:00 remaining)
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.19s latency).
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2f
Not shown: 996 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
9929/tcp  open  nping-echo
31337/tcp open  Elite
Device type: general purpose
Running: Linux 4.X
OS CPE: cpe:/o:linux:linux_kernel:4
OS details: Linux 4.19 - 5.15
Network Distance: 22 hops

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 26.37 seconds
```

Figure 6: Análisis de Información del sistema operativo de *ScanMe*

En esta imagen se puede apreciar el sistema operativo Linux 4.X. Como bien se puede entender, la detección remota no llega a ser tan precisa debido a posibles intermitencias al tener que recibir los datos. Es por ello que la información que tenemos del sistema operativo no es completa, sino que nos advierte de la versión general del kernel mas no la específica.

Enumeración SMB en entorno local

```
(msosa@msosa-kali)-[~]
$ enum4linux -a 192.168.56.20
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Thu Apr 16 10:54:23 2026

----- ( Target Information ) -----
Target ..... 192.168.56.20
RID Range ..... 500-550,1000-1050
Username ..... ''
Password ..... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none

----- ( Enumerating Workgroup/Domain on 192.168.56.20 ) -----

[E] Can't find workgroup/domain

----- ( Nbtstat Information for 192.168.56.20 ) -----

Looking up status of 192.168.56.20
No reply from 192.168.56.20

----- ( Session Check on 192.168.56.20 ) -----
```

Figure 7: Extracción de Información con *enum4linux*

Aquí puede observarse la IP a la que se refiere la máquina virtual de Ubuntu. Se puede ver que no se tiene el usuario ni contraseña de la máquina, no se especificó en el comando utilizado. Se pueden también observar los usuarios conocidos dentro de la máquina virtual. La información advierte también que no existe ningún dominio o grupo de trabajo, o que no pudo detectarla.

Conclusiones

- El reconocimiento es la fase inicial de cualquier ataque
- `scanme.nmap.org` permite practicar escaneo sin riesgo legal
- *SMB* puede exponer información sensible si está mal configurado
- `nmap` y `enum4linux` permiten analizar la superficie de ataque



UNIVERSIDAD DE LAS FUERZAS ARMADAS - ESPE

DEPARTAMENTO DE CIENCIAS DE LA COMPUTACIÓN
Ingeniería de la Seguridad del Software

Integrantes: Mateo Sosa

NRC: 30808

Fecha: April 30, 2026

Contents

Objetivos de Aprendizaje	3
Topología del Experimento	3
Marco Teórico	3
Escaneo	4
Enumeración	4
Análisis de Vulnerabilidades	4
Desarrollo	5
Reconocimiento Inicial	5
Escaneo de Puertos y Versiones	6
Enumeración de Servicios Específicos	7
Script y Análisis de Vulnerabilidades	8
Ejercicios	10
Escaneo general de vulnerabilidades	10
Escaneo rápido masivo	11
<i>Fingerprinting</i> y detección de versiones	12
Uso de Categorías NSE	13
Escaneo de vulnerabilidades SSL/TLS	14
Escaneo centrado en SMB/Windows	15
Conclusiones	15

List of Figures

1	Revisión de Conectividad entre Metasploitable y Kali	5
2	Escaneo de Servicios Detallado	6
3	Extracción de Información	7
4	Script de Vulnerabilidades	8
5	Ejecución del Script de Vulnerabilidades sobre Metasploitable	9

6	Panorama Rápido de Servicios y Posibles Vulnerabilidades	10
7	Identificación de Hosts Activos y Puertos Abiertos	11
8	Identificación de Sistema Operativo y Versiones	12
9	Detección de Problemas en Servicios Web y Aplicaciones	13
10	Identificación de Problemas en Capa TLS/SSL	14
11	Enumeración de Servicios SMB y Posibles Vulnerabilidades Relacionadas	15

Objetivos de Aprendizaje

Al finalizar esta práctica, usted será capaz de:

- Comprender la diferencia fundamental entre el reconocimiento pasivo y activo, y la enumeración de servicios.
- Identificar los flags (`-sS`, `-sV`, `-O`, `-sU`) y las técnicas clave de Nmap para realizar un mapeo completo de un sistema objetivo.
- Aplicar herramientas de escaneo y enumeración (Nmap y Enum4linux) en un entorno controlado (laboratorio virtual).
- Analizar y documentar los hallazgos para determinar posibles vectores de ataque iniciales.
- Aplicar el script `nmap --script=vuln` para automatizar la identificación de vulnerabilidades conocidas (Common Vulnerabilities and Exposures, CVEs) y configuraciones débiles en los servicios activos.

Topología del Experimento

El entorno debe ser aislado (red interna o Host-Only) para garantizar que el tráfico del taller no salga al exterior, cumpliendo con la ética profesional.

Rol	Sistema Operativo (VM)	Propósito	Configuración de Red
Atacante (Scanner)	Kali Linux (vía VirtualBox/VMware)	Ejecución de herramientas de escaneo y enumeración (Nmap, Enum4linux)	Adaptador de Red Interna (ej. 192.168.56.10)
Objetivo A (Víctima)	Metasploitable 2 (Linux vulnerable)	Host con múltiples vulnerabilidades y puertos abiertos, ideal para el escaneo	Adaptador de Red Interna (ej. 192.168.56.11)
Objetivo B (Simulación)	Ubuntu Desktop (o Windows Server de prueba)	Simula un entorno SMB/Samba para practicar la enumeración	Adaptador de Red Interna (ej. 192.168.56.12)

Marco Teórico

La Fase 2: Escaneo y Enumeración sigue al Reconocimiento (Footprinting) y busca interactuar activamente con el objetivo para extraer información detallada.

Escaneo

Es la etapa donde se envían paquetes a la red objetivo para identificar:

1. **Hosts Activos:** Usando ICMP o barrido de ping.
2. **Puertos Abiertos:** Utilizando técnicas como SYN Scan (**-sS**), que es más sigiloso que un escaneo de conexión (**-sT**) porque no completa el handshake TCP.
3. **Servicios y Versiones:** Determinando qué software específico se ejecuta en cada puerto abierto (ej. Apache, OpenSSH).

Enumeración

Es el proceso de extracción intensiva de información de un servicio o sistema operativo específico. Se utiliza la información recopilada en la fase de escaneo para:

- Obtener nombres de usuario válidos y listas de grupos.
- Identificar recursos compartidos (SMB/Samba).
- Extraer políticas de seguridad a nivel de sistema.

Análisis de Vulnerabilidades

Utiliza los datos de la fase de escaneo y enumeración (servicios y versiones) para evaluar las debilidades de un sistema.

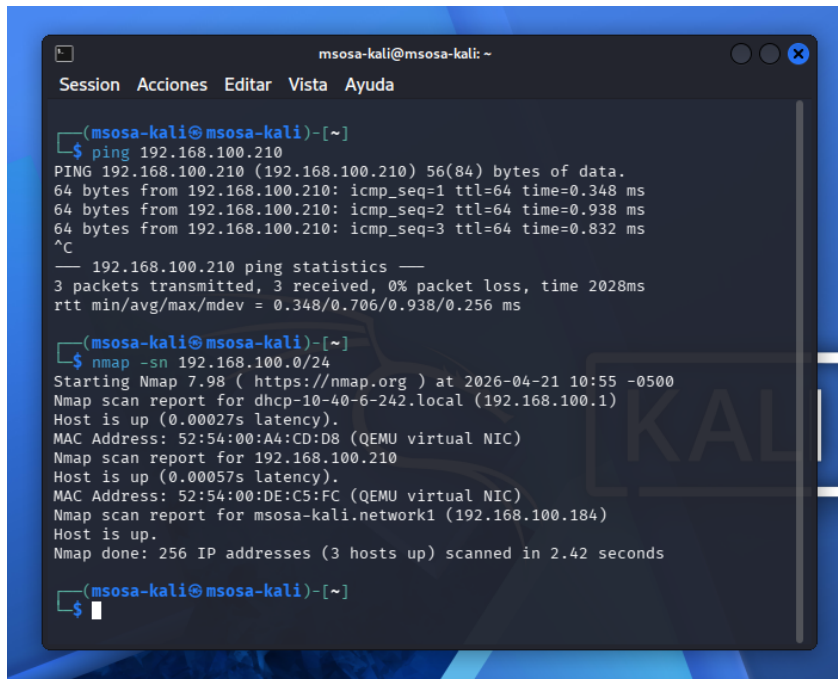
El script `nmap --script=vuln` es una herramienta esencial en esta fase. Permite:

- Detectar vulnerabilidades conocidas (CVEs).
- Identificar posibles backdoors.
- Verificar el uso de credenciales por defecto.
- Detectar debilidades en protocolos como SMB, FTP o SSH.

Al automatizar esta búsqueda, el ethical hacker puede priorizar objetivos para la siguiente fase: la explotación.

Desarrollo

Reconocimiento Inicial



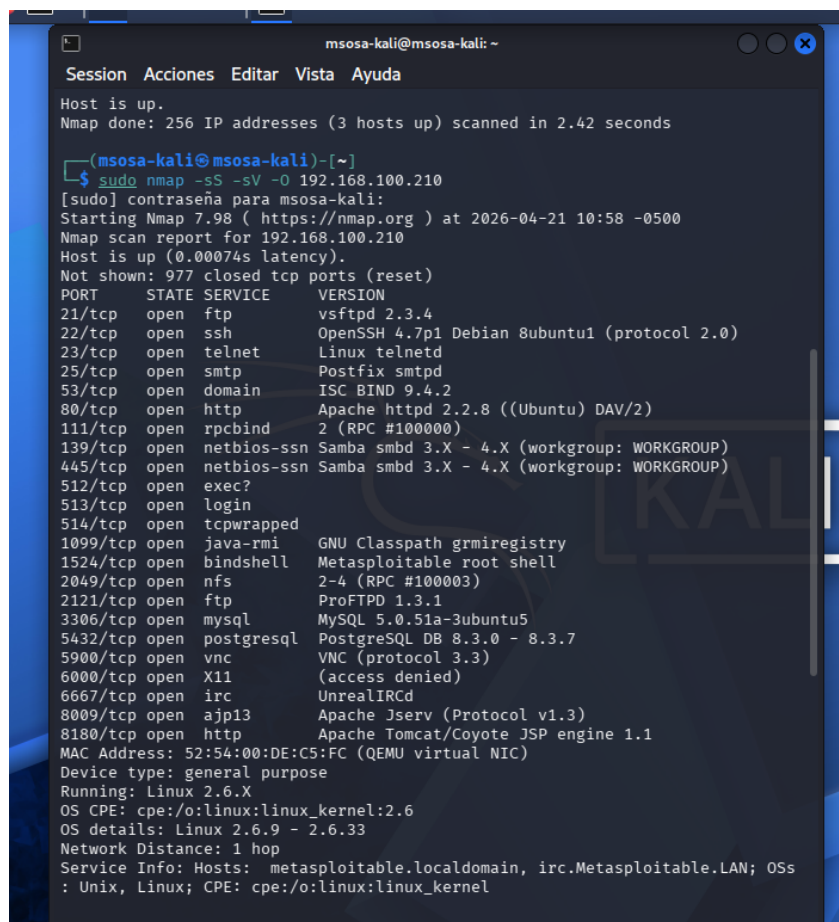
```
msosa-kali@msosa-kali: ~  
Session Acciones Editar Vista Ayuda  
  
(msosa-kali@msosa-kali)-[~]  
$ ping 192.168.100.210  
PING 192.168.100.210 (192.168.100.210) 56(84) bytes of data.  
64 bytes from 192.168.100.210: icmp_seq=1 ttl=64 time=0.348 ms  
64 bytes from 192.168.100.210: icmp_seq=2 ttl=64 time=0.938 ms  
64 bytes from 192.168.100.210: icmp_seq=3 ttl=64 time=0.832 ms  
^C  
--- 192.168.100.210 ping statistics ---  
3 packets transmitted, 3 received, 0% packet loss, time 2028ms  
rtt min/avg/max/mdev = 0.348/0.706/0.938/0.256 ms  
  
(msosa-kali@msosa-kali)-[~]  
$ nmap -sn 192.168.100.0/24  
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-21 10:55 -0500  
Nmap scan report for dhcp-10-40-6-242.local (192.168.100.1)  
Host is up (0.00027s latency).  
MAC Address: 52:54:00:A4:CD:D8 (QEMU virtual NIC)  
Nmap scan report for 192.168.100.210  
Host is up (0.00057s latency).  
MAC Address: 52:54:00:DE:C5:FC (QEMU virtual NIC)  
Nmap scan report for msosa-kali.network1 (192.168.100.184)  
Host is up.  
Nmap done: 256 IP addresses (3 hosts up) scanned in 2.42 seconds  
  
(msosa-kali@msosa-kali)-[~]  
$
```

Figure 1: Revisión de Conectividad entre Metasploitable y Kali

Para iniciar con el desarrollo, se debe constar una conexión entre ambos dispositivos, tal como se observa en la figura 1.

Se detectaron 3 dispositivos en la misma red.

Escaneo de Puertos y Versiones

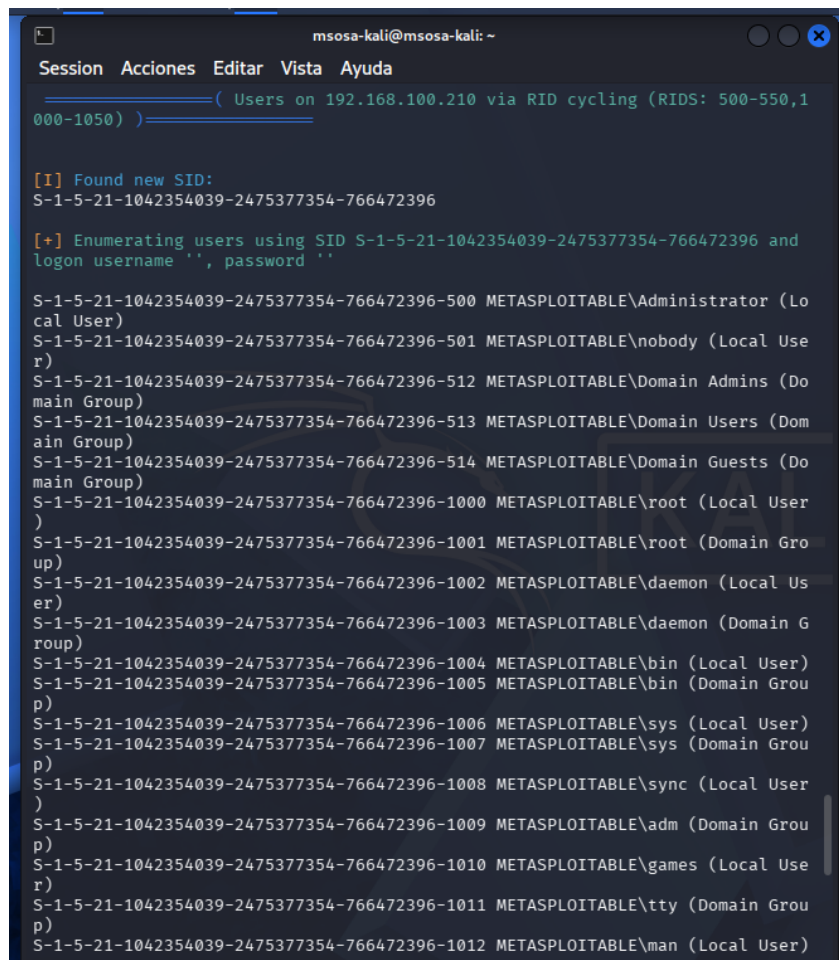


```
msosa-kali@msosa-kali: ~  
Session Acciones Editar Vista Ayuda  
Host is up.  
Nmap done: 256 IP addresses (3 hosts up) scanned in 2.42 seconds  
  
(msosa-kali@msosa-kali)-[~]  
$ sudo nmap -sS -sV -O 192.168.100.210  
[sudo] contraseña para msosa-kali:  
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-21 10:58 -0500  
Nmap scan report for 192.168.100.210  
Host is up (0.00074s latency).  
Not shown: 977 closed tcp ports (reset)  
PORT      STATE SERVICE      VERSION  
21/tcp    open  ftp          vsftpd 2.3.4  
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)  
23/tcp    open  telnet       Linux telnetd  
25/tcp    open  smtp         Postfix smtpd  
53/tcp    open  domain       ISC BIND 9.4.2  
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)  
111/tcp   open  rpcbind      2 (RPC #100000)  
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)  
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)  
512/tcp   open  exec?          
513/tcp   open  login          
514/tcp   open  tcpwrapped     
1099/tcp  open  java-rmi     GNU Classpath grmiregistry  
1524/tcp  open  bindshell    Metasploitable root shell  
2049/tcp  open  nfs          2-4 (RPC #100003)  
2121/tcp  open  ftp          ProFTPD 1.3.1  
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5  
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7  
5900/tcp  open  vnc          VNC (protocol 3.3)  
6000/tcp  open  X11          (access denied)  
6667/tcp  open  irc          UnrealIRCd  
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)  
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1  
MAC Address: 52:54:00:DE:C5:FC (QEMU virtual NIC)  
Device type: general purpose  
Running: Linux 2.6.X  
OS CPE: cpe:/o:linux:linux_kernel:2.6  
OS details: Linux 2.6.9 - 2.6.33  
Network Distance: 1 hop  
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs : Unix, Linux; CPE: cpe:/o:linux:linux_kernel
```

Figure 2: Escaneo de Servicios Detallado

La figura 2 detecta que la máquina virtual de Metasploitable tiene una versión de Linux 2.6.X, cuyo kernel es *linux_kernel:2.6*.

Enumeración de Servicios Específicos



```
msosa-kali@msosa-kali: ~  
Session Acciones Editar Vista Ayuda  
===== ( Users on 192.168.100.210 via RID cycling (RIDS: 500-550,1  
000-1050) ) =====  
  
[I] Found new SID:  
S-1-5-21-1042354039-2475377354-766472396  
  
[+] Enumerating users using SID S-1-5-21-1042354039-2475377354-766472396 and  
logon username '', password ''  
  
S-1-5-21-1042354039-2475377354-766472396-500 METASPLOITABLE\Administrator (Lo  
cal User)  
S-1-5-21-1042354039-2475377354-766472396-501 METASPLOITABLE\nobody (Local Use  
r)  
S-1-5-21-1042354039-2475377354-766472396-512 METASPLOITABLE\Domain Admins (Do  
main Group)  
S-1-5-21-1042354039-2475377354-766472396-513 METASPLOITABLE\Domain Users (Dom  
ain Group)  
S-1-5-21-1042354039-2475377354-766472396-514 METASPLOITABLE\Domain Guests (Do  
main Group)  
S-1-5-21-1042354039-2475377354-766472396-1000 METASPLOITABLE\root (Local User  
)  
S-1-5-21-1042354039-2475377354-766472396-1001 METASPLOITABLE\root (Domain Gro  
up)  
S-1-5-21-1042354039-2475377354-766472396-1002 METASPLOITABLE\daemon (Local Us  
er)  
S-1-5-21-1042354039-2475377354-766472396-1003 METASPLOITABLE\daemon (Domain G  
roup)  
S-1-5-21-1042354039-2475377354-766472396-1004 METASPLOITABLE\bin (Local User)  
S-1-5-21-1042354039-2475377354-766472396-1005 METASPLOITABLE\bin (Domain Grou  
p)  
S-1-5-21-1042354039-2475377354-766472396-1006 METASPLOITABLE\sys (Local User)  
S-1-5-21-1042354039-2475377354-766472396-1007 METASPLOITABLE\sys (Domain Grou  
p)  
S-1-5-21-1042354039-2475377354-766472396-1008 METASPLOITABLE\sync (Local User  
)  
S-1-5-21-1042354039-2475377354-766472396-1009 METASPLOITABLE\adm (Domain Grou  
p)  
S-1-5-21-1042354039-2475377354-766472396-1010 METASPLOITABLE\games (Local Use  
r)  
S-1-5-21-1042354039-2475377354-766472396-1011 METASPLOITABLE\tty (Domain Grou  
p)  
S-1-5-21-1042354039-2475377354-766472396-1012 METASPLOITABLE\man (Local User)
```

Figure 3: Extracción de Información

Como se puede observar en la figura 3, se hizo un ataque de fuerza bruta al objetivo, aunque no pudo encontrar ningún usuario o dominio.

Script y Análisis de Vulnerabilidades



```
msosa-kali@msosa-kali: ~  
Session Acciones Editar Vista Ayuda  
GNU nano 8.7.1 script_vuln.sh  
IP_ADDRESS='192.168.56.210'  
  
nmap -F -sV -v $IP_ADDRESS  
  
sudo nmap -sV --script=vuln -v $IP_ADDRESS  
  
nmap -sV -v $IP_ADDRESS  
  
nmap -sV -p 1-65535 -T4 $IP_ADDRESS  
  
nmap -sV --script=banner $IP_ADDRESS  
  
[ 11 líneas leídas ]  
^G Ayuda    ^O Guardar  ^F Buscar   ^K Cortar   ^T Ejecutar  
^X Salir    ^R Leer fich.^_ Reemplazar ^U Pegar    ^J Justificar
```

Figure 4: Script de Vulnerabilidades

El script de vulnerabilidades es el siguiente:

```
# IP de Metasploitable  
IP_ADDRESS='192.168.56.210'  
  
# Comandos para vulnerar  
nmap -F -sV -v $IP_ADDRESS  
  
sudo nmap -sV --script=vuln -v $IP_ADDRESS  
  
nmap -sV -v $IP_ADDRESS  
  
nmap -sV -p 1-65535 -T4 $IP_ADDRESS  
  
nmap -sV --script=banner $IP_ADDRESS
```

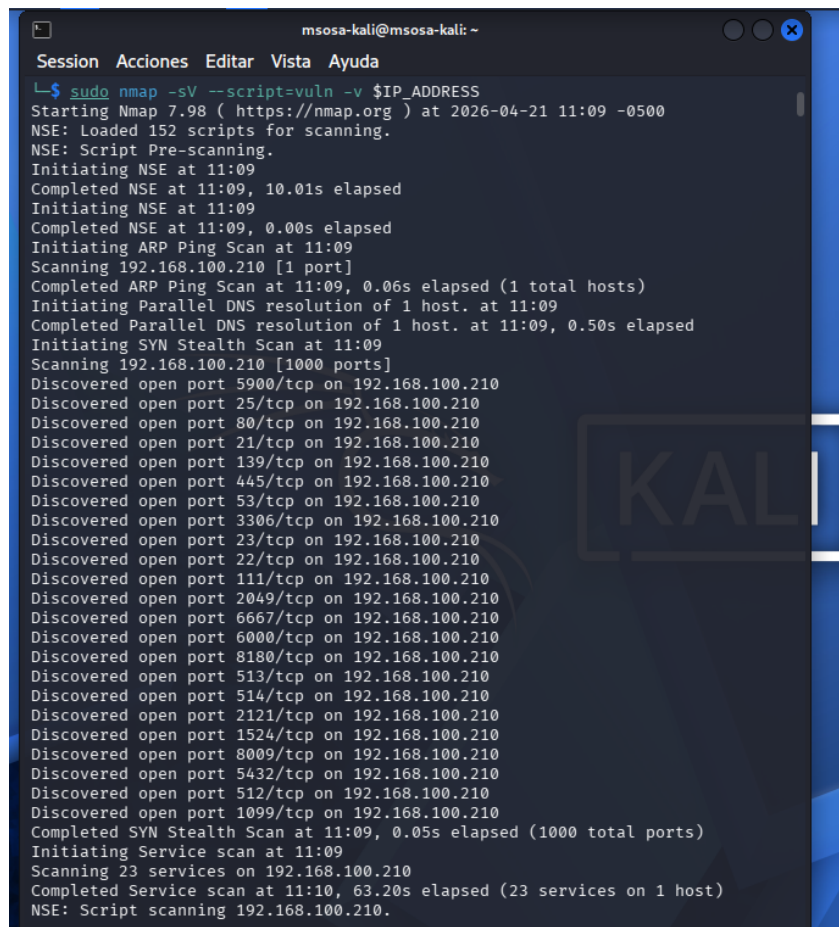
```
msosa-kali@msosa-kali: ~  
Session Acciones Editar Vista Ayuda  
(msosa-kali@msosa-kali)-[~]  
$ sh script_vuln.sh  
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-21 11:06 -0500  
NSE: Loaded 48 scripts for scanning.  
Initiating Ping Scan at 11:06  
Scanning 192.168.56.210 [4 ports]  
Completed Ping Scan at 11:06, 3.02s elapsed (1 total hosts)  
Nmap scan report for 192.168.56.210 [host down]  
Read data files from: /usr/share/nmap  
Note: Host seems down. If it is really up, but blocking our ping probes, try  
-Pn  
Nmap done: 1 IP address (0 hosts up) scanned in 3.17 seconds  
Raw packets sent: 8 (304B) | Rcvd: 0 (0B)  
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-21 11:06 -0500  
NSE: Loaded 152 scripts for scanning.  
NSE: Script Pre-scanning.  
Initiating NSE at 11:06  
Completed NSE at 11:06, 10.01s elapsed  
Initiating NSE at 11:06  
Completed NSE at 11:06, 0.00s elapsed  
Initiating Ping Scan at 11:06  
Scanning 192.168.56.210 [4 ports]  
Completed Ping Scan at 11:06, 3.03s elapsed (1 total hosts)  
Nmap scan report for 192.168.56.210 [host down]  
NSE: Script Post-scanning.  
Initiating NSE at 11:06  
Completed NSE at 11:06, 0.00s elapsed  
Initiating NSE at 11:06  
Completed NSE at 11:06, 0.00s elapsed  
Read data files from: /usr/share/nmap  
Note: Host seems down. If it is really up, but blocking our ping probes, try  
-Pn  
Nmap done: 1 IP address (0 hosts up) scanned in 13.32 seconds  
Raw packets sent: 8 (304B) | Rcvd: 0 (0B)  
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-21 11:06 -0500  
NSE: Loaded 48 scripts for scanning.  
Initiating Ping Scan at 11:06  
Scanning 192.168.56.210 [4 ports]  
Completed Ping Scan at 11:07, 3.02s elapsed (1 total hosts)  
Nmap scan report for 192.168.56.210 [host down]  
Read data files from: /usr/share/nmap  
Note: Host seems down. If it is really up, but blocking our ping probes, try  
-Pn
```

Figure 5: Ejecución del Script de Vulnerabilidades sobre Metasploitable

En la ejecución del script mostrada en la figura 5, se aprecian los fallos de seguridad concretos de la máquina virtual.

Ejercicios

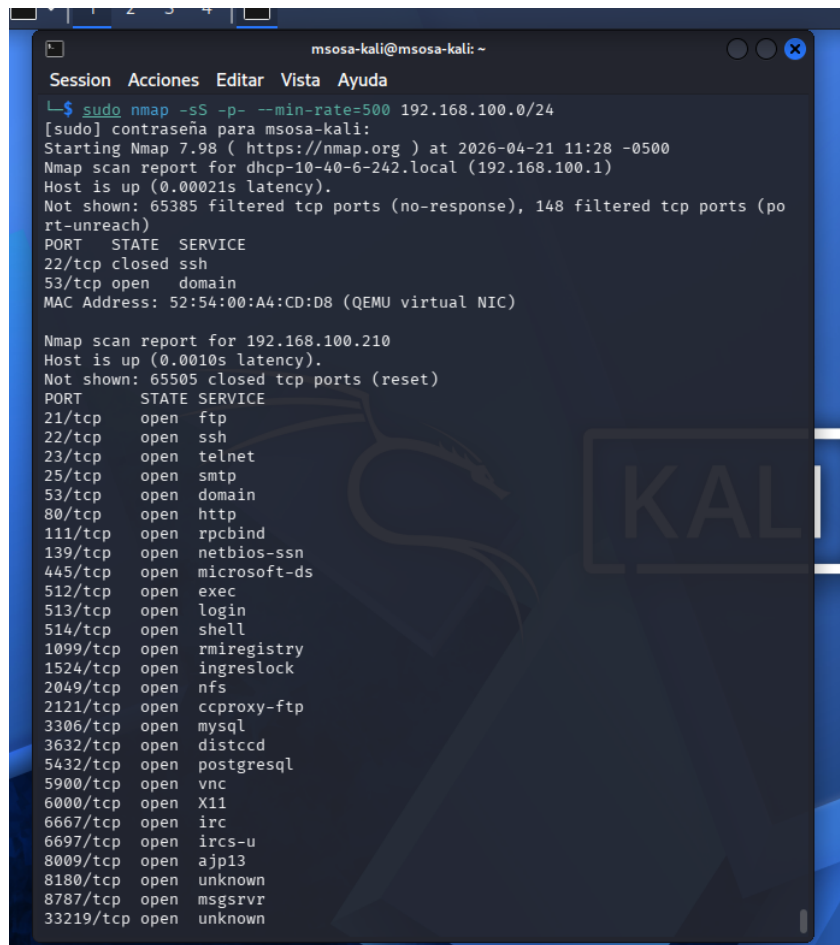
Escaneo general de vulnerabilidades



```
msosa-kali@msosa-kali: ~  
Session Acciones Editar Vista Ayuda  
└─$ sudo nmap -sV --script=vuln -v $IP_ADDRESS  
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-21 11:09 -0500  
NSE: Loaded 152 scripts for scanning.  
NSE: Script Pre-scanning.  
Initiating NSE at 11:09  
Completed NSE at 11:09, 10.01s elapsed  
Initiating NSE at 11:09  
Completed NSE at 11:09, 0.00s elapsed  
Initiating ARP Ping Scan at 11:09  
Scanning 192.168.100.210 [1 port]  
Completed ARP Ping Scan at 11:09, 0.06s elapsed (1 total hosts)  
Initiating Parallel DNS resolution of 1 host. at 11:09  
Completed Parallel DNS resolution of 1 host. at 11:09, 0.50s elapsed  
Initiating SYN Stealth Scan at 11:09  
Scanning 192.168.100.210 [1000 ports]  
Discovered open port 5900/tcp on 192.168.100.210  
Discovered open port 25/tcp on 192.168.100.210  
Discovered open port 80/tcp on 192.168.100.210  
Discovered open port 21/tcp on 192.168.100.210  
Discovered open port 139/tcp on 192.168.100.210  
Discovered open port 445/tcp on 192.168.100.210  
Discovered open port 53/tcp on 192.168.100.210  
Discovered open port 3306/tcp on 192.168.100.210  
Discovered open port 23/tcp on 192.168.100.210  
Discovered open port 22/tcp on 192.168.100.210  
Discovered open port 111/tcp on 192.168.100.210  
Discovered open port 2049/tcp on 192.168.100.210  
Discovered open port 6667/tcp on 192.168.100.210  
Discovered open port 6000/tcp on 192.168.100.210  
Discovered open port 8180/tcp on 192.168.100.210  
Discovered open port 513/tcp on 192.168.100.210  
Discovered open port 514/tcp on 192.168.100.210  
Discovered open port 2121/tcp on 192.168.100.210  
Discovered open port 1524/tcp on 192.168.100.210  
Discovered open port 8009/tcp on 192.168.100.210  
Discovered open port 5432/tcp on 192.168.100.210  
Discovered open port 512/tcp on 192.168.100.210  
Discovered open port 1099/tcp on 192.168.100.210  
Completed SYN Stealth Scan at 11:09, 0.05s elapsed (1000 total ports)  
Initiating Service scan at 11:09  
Scanning 23 services on 192.168.100.210  
Completed Service scan at 11:10, 63.20s elapsed (23 services on 1 host)  
NSE: Script scanning 192.168.100.210.
```

Figure 6: Panorama Rápido de Servicios y Posibles Vulnerabilidades

Escaneo rápido masivo



The screenshot shows a terminal window titled 'msosa-kali@msosa-kali: ~'. The terminal displays the output of an Nmap scan command: `sudo nmap -ss -p- --min-rate=500 192.168.100.0/24`. The output shows the scan starting at 2026-04-21 11:28 -0500. The first host scanned is 192.168.100.1 (dhcp-10-40-6-242.local), which is up with a latency of 0.00021s. It has 148 filtered TCP ports. The second host scanned is 192.168.100.210, which is up with a latency of 0.0010s. It has 65505 closed TCP ports (reset). The terminal also displays a list of open ports and services for the second host.

```
Session Acciones Editar Vista Ayuda
└─$ sudo nmap -ss -p- --min-rate=500 192.168.100.0/24
[sudo] contraseña para msosa-kali:
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-21 11:28 -0500
Nmap scan report for dhcp-10-40-6-242.local (192.168.100.1)
Host is up (0.00021s latency).
Not shown: 65385 filtered tcp ports (no-response), 148 filtered tcp ports (po
rt-unreach)
PORT      STATE  SERVICE
22/tcp    closed ssh
53/tcp    open   domain
MAC Address: 52:54:00:A4:CD:D8 (QEMU virtual NIC)

Nmap scan report for 192.168.100.210
Host is up (0.0010s latency).
Not shown: 65505 closed tcp ports (reset)
PORT      STATE  SERVICE
21/tcp    open   ftp
22/tcp    open   ssh
23/tcp    open   telnet
25/tcp    open   smtp
53/tcp    open   domain
80/tcp    open   http
111/tcp   open   rpcbind
139/tcp   open   netbios-ssn
445/tcp   open   microsoft-ds
512/tcp   open   exec
513/tcp   open   login
514/tcp   open   shell
1099/tcp  open   rmiregistry
1524/tcp  open   ingreslock
2049/tcp  open   nfs
2121/tcp  open   ccproxy-ftp
3306/tcp  open   mysql
3632/tcp  open   distccd
5432/tcp  open   postgresql
5900/tcp  open   vnc
6000/tcp  open   X11
6667/tcp  open   irc
6697/tcp  open   ircs-u
8009/tcp  open   ajp13
8180/tcp  open   unknown
8787/tcp  open   msgsrvr
33219/tcp open   unknown
```

Figure 7: Identificación de Hosts Activos y Puertos Abiertos

Fingerprinting y detección de versiones

```
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-28 10:46 -0500
Nmap scan report for 192.168.100.210
Host is up (0.00065s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ftp-syst:
|_STAT:
|_FTP server status:
|_Connected to 192.168.100.184
|_Logged in as ftp
|_TYPE: ASCII
|_No session bandwidth limit
|_Session timeout in seconds is 300
|_Control connection is plain text
|_Data connections will be plain text
|_vsFTPD 2.3.4 - secure, fast, stable
|_End of status
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_ssh-hostkey:
|_1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
|_ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName
=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
|_Not valid before: 2010-03-17T14:07:45
|_Not valid after: 2010-04-16T14:07:45
|_smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRF
Y, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
|_ssl-date: 2026-04-28T15:47:22+00:00; 0s from scanner time.
|_sslv2:
|_SSLv2 supported
|_ciphers:
|_SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|_SSL2_RC4_128_WITH_MD5
|_SSL2_DES_64_CBC_WITH_MD5
|_SSL2_RC2_128_CBC_WITH_MD5
|_SSL2_RC4_128_EXPORT40_WITH_MD5
|_SSL2_DES_192_EDE3_CBC_WITH_MD5
|_
53/tcp    open  domain       ISC BIND 9.4.2
|_dns-nsid:
```

Figure 8: Identificación de Sistema Operativo y Versiones

Uso de Categorías NSE

```
l-$ nmap -p 80,443 --script "http-enum,http-vuln*" -v 192.168.100.210
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-28 10:48 -0500
NSE: Loaded 25 scripts for scanning.
NSE: Script Pre-scanning.
Initiating NSE at 10:48
Completed NSE at 10:48, 0.00s elapsed
Initiating ARP Ping Scan at 10:48
Scanning 192.168.100.210 [1 port]
Completed ARP Ping Scan at 10:48, 0.06s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 10:48
Completed Parallel DNS resolution of 1 host. at 10:48, 0.50s elapsed
Initiating SYN Stealth Scan at 10:48
Scanning 192.168.100.210 [2 ports]
Discovered open port 80/tcp on 192.168.100.210
Completed SYN Stealth Scan at 10:48, 0.01s elapsed (2 total ports)
NSE: Script scanning 192.168.100.210.
Initiating NSE at 10:48
Completed NSE at 10:48, 1.32s elapsed
Nmap scan report for 192.168.100.210
Host is up (0.00081s latency).

PORT      STATE SERVICE
80/tcp    open  http
|_http-vuln-cve2017-1001000: ERROR: Script execution failed (use -d to debug)
| http-enum:
|   /tikiwiki/: Tikiwiki
|   /test/: Test page
|   /phpinfo.php: Possible information file
|   /phpMyAdmin/: phpMyAdmin
|   /doc/: Potentially interesting directory w/ listing on 'apache/2.2.8 (ubuntu) dav/2'
|   /icons/: Potentially interesting folder w/ directory listing
|_  /index/: Potentially interesting folder
443/tcp    closed https
MAC Address: 52:54:00:DE:C5:FC (QEMU virtual NIC)

NSE: Script Post-scanning.
Initiating NSE at 10:48
Completed NSE at 10:48, 0.00s elapsed
Read data files from: /usr/share/nmap
Nmap done: 1 IP address (1 host up) scanned in 2.11 seconds
Raw packets sent: 3 (116B) | Rcvd: 3 (112B)
```

Figure 9: Detección de Problemas en Servicios Web y Aplicaciones

Escaneo de vulnerabilidades SSL/TLS

```
(msosa-kali@msosa-kali)-[~]
$ nmap --script ssl-enum-ciphers -p 443 192.168.100.210
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-28 10:48 -0500
Nmap scan report for 192.168.100.210
Host is up (0.00089s latency).

PORT      STATE SERVICE
443/tcp    closed https
MAC Address: 52:54:00:DE:C5:FC (QEMU virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.74 seconds

(msosa-kali@msosa-kali)-[~]
$
```

Figure 10: Identificación de Problemas en Capa TLS/SSL

Escaneo centrado en SMB/Windows

```
└─$ nmap -p 139,445 --script "smb-enum-users,smb-enum-shares,smb-vuln*" 192
.168.100.210
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-28 10:49 -0500
Nmap scan report for 192.168.100.210
Host is up (0.00060s latency).

PORT      STATE SERVICE
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
MAC Address: 52:54:00:DE:C5:FC (QEMU virtual NIC)

Host script results:
| smb-enum-users:
| METASPLOITABLE\backup (RID: 1068)
|   Full name: backup
|   Flags: Account disabled, Normal user account
| METASPLOITABLE\bin (RID: 1004)
|   Full name: bin
|   Flags: Account disabled, Normal user account
| METASPLOITABLE\bind (RID: 1210)
|   Flags: Account disabled, Normal user account
| METASPLOITABLE\daemon (RID: 1002)
|   Full name: daemon
|   Flags: Account disabled, Normal user account
| METASPLOITABLE\dhcp (RID: 1202)
|   Flags: Account disabled, Normal user account
| METASPLOITABLE\distccd (RID: 1222)
|   Flags: Account disabled, Normal user account
| METASPLOITABLE\ftp (RID: 1214)
|   Flags: Account disabled, Normal user account
| METASPLOITABLE\games (RID: 1010)
|   Full name: games
|   Flags: Account disabled, Normal user account
| METASPLOITABLE\gnats (RID: 1082)
|   Full name: Gnats Bug-Reporting System (admin)
|   Flags: Account disabled, Normal user account
| METASPLOITABLE\irc (RID: 1078)
|   Full name: ircd
|   Flags: Account disabled, Normal user account
| METASPLOITABLE\klog (RID: 1206)
|   Flags: Account disabled, Normal user account
| METASPLOITABLE\libuuidd (RID: 1200)
|   Flags: Account disabled, Normal user account
```

Figure 11: Enumeración de Servicios SMB y Posibles Vulnerabilidades Relacionadas

Conclusiones

- La fase de escaneo representa la transición de reconocimiento pasivo a activo.
- La combinación `nmap -sS -sV -O` es un estándar para obtener información detallada del objetivo.
- La enumeración transforma datos generales (puertos abiertos) en información útil para explotación (usuarios, recursos).
- Todas las prácticas deben ejecutarse en entornos aislados, respetando principios éticos del hacking.



UNIVERSIDAD DE LAS FUERZAS ARMADAS - ESPE

DEPARTAMENTO DE CIENCIAS DE LA COMPUTACIÓN

Ingeniería de la Seguridad del Software

Integrantes: Mateo Sosa

NRC: 30808

Fecha: April 30, 2026

Contents

Objetivos de aprendizaje	2
Topología	2
Marco Teórico	2
Introducción a los keylogger	2
Clasificación de los keyloggers	2
Keyloggers de software	2
Keyloggers de hardware	2
Keyloggers basados en kernel	3
Funcionamiento de los keyloggers en sistemas operativos	3
Kali Linux en el análisis de seguridad	3
Desarrollo de keyloggers con Python	3
Detección y mitigación de keyloggers	3
Consideraciones éticas y legales	4
Desarrollo	4
Instalación y Configuración del Keylogger	4
Instalar Logkeys en Kali Linux	4
Configurar Logkeys	5
Verificar la ejecución del Keylogger	5
Conclusión de la práctica	5

List of Figures

1	Instalación de Paquete KeyLogger	4
2	Configuración de xspy en Segundo Plano	5
3	Revisión de Ejecución de xspy	5

Objetivos de aprendizaje

- Los estudiantes comprendan el funcionamiento de un keylogger y su implementación en un entorno controlado utilizando Kali Linux.
- Los estudiantes aprenderán a configurar y ejecutar un keylogger, observarán su funcionamiento, y analizarán su impacto en la seguridad.
- Los estudiantes abordarán aspectos éticos relacionados con el uso de este tipo de herramientas.

Topología

1. Kali Linux (máquina atacante).
2. Windows o Linux (máquina víctima, puede ser una máquina virtual), o a su vez la VM Metasploitable 2.
3. Keylogger libre
4. Wireshark o iptraf (para análisis de red, opcional).

Marco Teórico

Introducción a los keylogger

Los keyloggers (registradores de teclas) son herramientas diseñadas para capturar las pulsaciones realizadas por un usuario en un dispositivo. Originalmente, estas tecnologías surgieron con fines legítimos, como la auditoría de sistemas, control parental y pruebas de usabilidad. Sin embargo, también son ampliamente utilizadas en el ámbito del malware para el robo de información sensible, como credenciales, datos bancarios y mensajes privados. Desde la perspectiva de la ciberseguridad, los keyloggers se clasifican como una forma de software espía (spyware), ya que operan de manera oculta y recopilan información sin el consentimiento del usuario.

Clasificación de los keyloggers

Los keyloggers pueden clasificarse según su implementación y nivel de operación.

Keyloggers de software

Funcionan a nivel del sistema operativo y pueden implementarse mediante:

- Hooks del teclado (intercepción de eventos)
- APIs del sistema
- Modificación de controladores

Este tipo es común en entornos de desarrollo como Python debido a su facilidad de implementación.

Keyloggers de hardware

Son dispositivos físicos conectados entre el teclado y la computadora. No requieren instalación de software y son más difíciles de detectar mediante herramientas tradicionales.

Keyloggers basados en kernel

Operan a nivel del núcleo del sistema operativo, lo que les permite evadir muchos mecanismos de detección convencionales. Este tipo está asociado a técnicas avanzadas como rootkits.

Funcionamiento de los keyloggers en sistemas operativos

En sistemas basados en Linux, como Kali Linux, los eventos de entrada del teclado son gestionados a través de subsistemas específicos del kernel (por ejemplo, `/dev/input`).

Un keylogger puede interceptar estos eventos mediante:

- Lectura directa de dispositivos de entrada
- Uso de bibliotecas de captura de eventos
- Intercepción en espacio de usuario

En el caso de implementaciones en Python, se utilizan bibliotecas que permiten acceder a eventos del teclado, facilitando la creación de prototipos con fines educativos.

Kali Linux en el análisis de seguridad

Kali Linux es una distribución de Linux orientada a pruebas de penetración y auditorías de seguridad. Incluye herramientas especializadas para:

- Análisis de malware
- Pruebas de vulnerabilidades
- Evaluación de seguridad en sistemas

El uso de Kali Linux en esta práctica permite a los estudiantes comprender cómo se analizan herramientas potencialmente maliciosas en entornos controlados.

Desarrollo de keyloggers con Python

Python es un lenguaje ampliamente utilizado en ciberseguridad debido a su simplicidad y gran ecosistema de bibliotecas. En el contexto educativo, permite:

- Comprender la lógica de captura de eventos
- Simular comportamientos de software malicioso en entornos controlados
- Analizar patrones de funcionamiento

Es importante destacar que el desarrollo de este tipo de software debe realizarse únicamente con fines académicos y en entornos controlados.

Detección y mitigación de keyloggers

La detección de keyloggers es un desafío debido a su naturaleza sigilosa. Algunas técnicas incluyen:

- Monitoreo de procesos sospechosos
- Análisis del comportamiento del sistema
- Uso de software antivirus y herramientas de análisis forense
- Control de acceso a dispositivos de entrada

Las soluciones modernas se basan en el análisis de comportamiento más que en firmas, debido a la evolución constante del malware.

Consideraciones éticas y legales

El desarrollo y uso de keyloggers sin consentimiento es ilegal en muchos países y constituye una violación grave de la privacidad. En el contexto académico, su estudio debe estar limitado a:

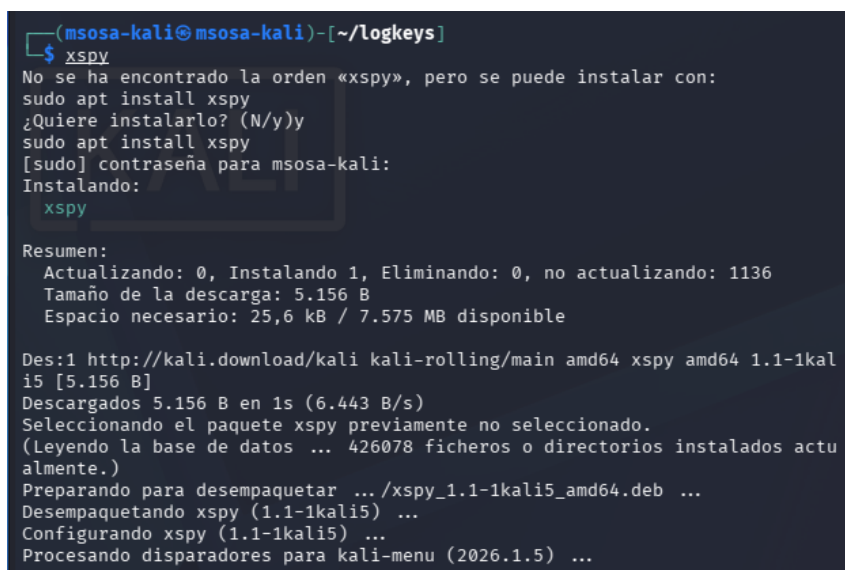
- Entornos controlados
- Fines educativos
- Análisis de seguridad

Es fundamental que los estudiantes comprendan las implicaciones éticas del uso de estas herramientas y promuevan prácticas responsables en ciberseguridad

Desarrollo

Instalación y Configuración del Keylogger

Instalar Logkeys en Kali Linux



```
(msosa-kali@msosa-kali)-[~/logkeys]
$ xspy
No se ha encontrado la orden «xspy», pero se puede instalar con:
sudo apt install xspy
¿Quiere instalarlo? (N/y)y
sudo apt install xspy
[sudo] contraseña para msosa-kali:
Instalando:
  xspy

Resumen:
  Actualizando: 0, Instalando 1, Eliminando: 0, no actualizando: 1136
  Tamaño de la descarga: 5.156 B
  Espacio necesario: 25,6 kB / 7.575 MB disponible

Des:1 http://kali.download/kali kali-rolling/main amd64 xspy amd64 1.1-1kal
i5 [5.156 B]
Descargados 5.156 B en 1s (6.443 B/s)
Seleccionando el paquete xspy previamente no seleccionado.
(Leyendo la base de datos ... 426078 ficheros o directorios instalados actu
almente.)
Preparando para desempaquetar .../xspy_1.1-1kali5_amd64.deb ...
Desempaquetando xspy (1.1-1kali5) ...
Configurando xspy (1.1-1kali5) ...
Procesando disparadores para kali-menu (2026.1.5) ...
```

Figure 1: Instalación de Paquete KeyLogger

La instalación del paquete **keylogger** no está disponible en las últimas versiones del repositorio de Ubuntu. La solución fue instalar un nuevo paquete llamado **xspy**, el cual permite conocer qué teclas se están presionando.

Configurar Logkeys

```
(msosa-kali@msosa-kali)~[/logkeys]
$ xspy > teclas.log 2>&1 &
[1] 22456
```

Figure 2: Configuración de xspy en Segundo Plano

Para configurar el LogKey, se optó por ponerlo en segundo plano para que no se detecte su salida. El comando utilizado fue:

```
xspy > teclas.log 2>&1 &
```

donde se puede apreciar que se guarda en el archivo `teclas.log` e, incluso, guarda la salida del teclado y los errores que puedan darse.

Verificar la ejecución del Keylogger

```
(msosa-kali@msosa-kali)~[/logkeys]
$ sudo systemctl status ssh
o ssh.service - OpenBSD Secure Shell server
  Loaded: loaded (/usr/lib/systemd/system/ssh.service; disabled; preset▶
  Active: inactive (dead)
  Docs: man:sshd(8)
        man:sshd_config(5)

(msosa-kali@msosa-kali)~[/logkeys]
$ cat ./teclas.log
opened :0.0 for snoopng
KP_Enter sdBackSpaceBackSpacesudo systemctl status shsBackSpaceBackSpacesh
qcat periodShift_R 7lBackSpacetecTab
```

Figure 3: Revisión de Ejecución de xspy

En la figura 3, se puede apreciar el comando que se buscó, que en este caso fue un:

```
sudo systemctl status ssh
```

Como se puede observar en el output obtenido del archivo, está escrito el comando, mas no su ejecución, puesto que el programa `xspy` únicamente toma en cuenta las teclas presionadas.

Conclusión de la práctica

Al final de esta práctica, los estudiantes habrán adquirido experiencia práctica con el uso de un keylogger en un entorno controlado, comprendiendo tanto su funcionamiento como las consecuencias de su uso en términos de seguridad informática. Así mismo aprenderá a programar un keylogger en Python a detectarlo y a mitigarlo.

Se enfatiza la importancia de la ética en el campo de la ingeniería y la seguridad, especialmente cuando se trata de herramientas que pueden invadir la privacidad de las personas.



UNIVERSIDAD DE LAS FUERZAS ARMADAS - ESPE

DEPARTAMENTO DE CIENCIAS DE LA COMPUTACIÓN

Ingeniería de la Seguridad del Software

Integrantes: Mateo Sosa

NRC: 30808

Fecha: April 30, 2026

Contents

Objetivos de Aprendizaje	3
Topología del experimento	3
Software requerido	3
Herramientas	3
Marco Teórico	4
FIPS PUB 200	4
Desarrollo	5
Reconocimiento	5
Simulación de Ataque	6
Implementación de Controles	6
Monitoreo de Tráfico	7
Autenticación y Seguridad	8
Ejemplos	8
Política de Contraseñas	8
Política de Complejidad de Contraseñas	9
Conclusiones	9

List of Figures

1	Topología de Experimentación	4
2	Identificación de Servicios Activos	5
3	Escaneo de Puertos y Servicios Vulnerables	6
4	Activación de Firewall	6
5	Revisión de Conexiones Activas	7
6	Wireshark en Kali	7
7	Políticas de Seguridad y Autenticación	8
8	Configuración de Archivo de Credenciales	8

9	Comprobación de Nueva Configuración de Contraseñas	9
10	Configuración de Archivo para Contraseñas Seguras	9

Objetivos de Aprendizaje

Al finalizar esta práctica, usted será capaz de:

- Comprender e implementar controles básicos de seguridad basados en NIST
- Analizar vulnerabilidades en sistemas expuestos
- Aplicar mecanismos de monitoreo, autenticación y control de acceso
- Evaluar eventos de seguridad mediante análisis de logs
- Relacionar la práctica con dominios de seguridad como auditoría, autenticación y protección de sistemas

Topología del experimento

La Figura 1 representa un laboratorio de pruebas de penetración (pentesting), en el cual el atacante utiliza Kali Linux para ejecutar técnicas de reconocimiento y explotación sobre Metasploitable 2, una máquina virtual diseñada con vulnerabilidades intencionales.

De manera complementaria, la VM con Ubuntu Desktop cumple el rol de sistema de monitoreo y análisis, desde donde se emplean herramientas de inspección de tráfico y revisión de registros para identificar indicios de intrusión y evaluar la efectividad de los controles de seguridad implementados.

Para lograr una visibilidad adecuada del tráfico, este sistema debe configurarse en un entorno de red que permita la captura de paquetes o el acceso a los logs generados por los sistemas analizados.

Software requerido

- VirtualBox / VMware
- Kali Linux
- Metasploitable 2
- Ubuntu Desktop

Herramientas

- Nmap
- Wireshark
- Netstat
- UFW (firewall)

El estudiante deberá presentar en su informe de laboratorio:

- Evidencia del escaneo realizado (capturas de Nmap)
- Identificación de vulnerabilidades detectadas
- Configuración aplicada en el firewall
- Capturas del análisis de tráfico con Wireshark
- Análisis de logs generados durante la práctica



Figure 1: Topología de Experimentación

Marco Teórico

El estándar **NIST SP 800-171** define un conjunto de controles mínimos para proteger información sensible en sistemas no federales. Estos controles se agrupan en dominios como:

- Control de acceso
- Auditoría
- Autenticación
- Integridad de la información

En entornos de laboratorio, estos principios pueden aplicarse mediante la simulación de ataques y la implementación de mecanismos de defensa en sistemas vulnerables.

FIPS PUB 200

FIPS significa *Federal Information Processing Standards*. Es un conjunto de normas de seguridad publicadas por el gobierno de Estados Unidos a través del NIST.

Define cómo deben protegerse y procesarse los datos sensibles en sistemas informáticos.

En la práctica, **FIPS** establece reglas sobre:

- Cifrado de datos
- Autenticación segura
- Integridad de la información
- Requisitos de seguridad en hardware y software

Desarrollo

Reconocimiento

```
(msosa-kali@msosa-kali)-[~]
$ nmap -sV 192.168.100.210
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-28 10:31 -0500
Nmap scan report for 192.168.100.210
Host is up (0.00045s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec?
513/tcp   open  login        OpenBSD or Solaris rlogind
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 52:54:00:DE:C5:FC (QEMU virtual NIC)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OS: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 64.14 seconds
```

Figure 2: Identificación de Servicios Activos

En la figura se pueden apreciar los servicios activos en Metasploitable. En listado, se pueden encontrar todos los puertos que mantiene abiertos.

Simulación de Ataque

```
└─$ nmap -A 192.168.100.210
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-28 10:35 -0500
Nmap scan report for 192.168.100.210
Host is up (0.0011s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
| ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to 192.168.100.184
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     vsFTPd 2.3.4 - secure, fast, stable
|_End of status
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_  2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
| sslv2:
|   SSLv2 supported
|   ciphers:
|     SSL2_RC4_128_EXPORT40_WITH_MD5
|     SSL2_DES_64_CBC_WITH_MD5
|     SSL2_RC2_128_CBC_WITH_MD5
|     SSL2_RC4_128_WITH_MD5
|     SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|_  SSL2_DES_192_EDE3_CBC_WITH_MD5
|_smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRF
Y, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
|_ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName
=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
|_Not valid before: 2010-03-17T14:07:45
|_Not valid after:  2010-04-16T14:07:45
|_ssl-date: 2026-04-28T15:36:50+00:00; 0s from scanner time.
53/tcp    open  domain       ISC BIND 9.4.2
```

Figure 3: Escaneo de Puertos y Servicios Vulnerables

Con el comando `nmap -A 192.168.100.210` se puede comprobar toda la información de todos los puertos abiertos que mantiene Metasploitable. Esto permite conocer qué servicios vulnerables tiene y cuáles podemos atacar.

Implementación de Controles

```
(msosa-kali@msosa-kali)-[~]
└─$ sudo ufw enable
[sudo] contraseña para msosa-kali:
Firewall is active and enabled on system startup

(msosa-kali@msosa-kali)-[~]
└─$ sudo ufw deny from 192.168.122.226
Rule added
```

Figure 4: Activación de Firewall

En la figura 4 se puede apreciar que se hizo un bloqueo a la dirección IP de Metasploitable para que esta no pueda acceder a los mismos servicios a los que quiere acceder.

```
msosa-kali@msosa-kali:~$ netstat -tulnp
(netstat -tulnp)
(Not all processes could be identified, non-owned process info
will not be shown, you would have to be root to see it all.)
Active Internet connections (only servers)
Proto Recv-Q Send-Q Local Address           Foreign Address         State
PID/Program name
```

Figure 5: Revisión de Conexiones Activas

Además, en la figura 5 se puede apreciar cuáles son las conexiones activas que mantiene el dispositivo.

Monitoreo de Tráfico

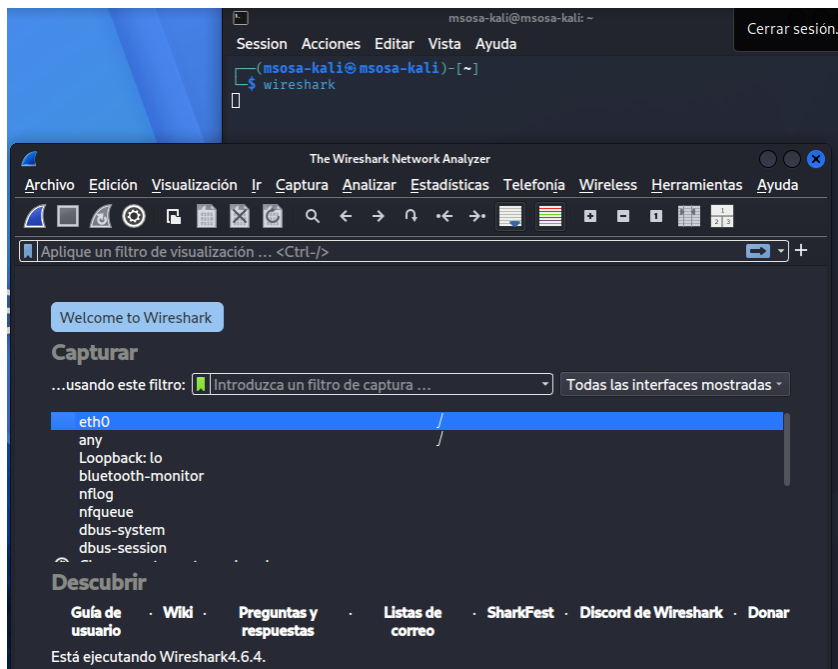


Figure 6: Wireshark en Kali

La aplicación de Wireshark permite conocer el tráfico que transita por el dispositivo, permitiendo entender cuáles y a dónde salen nuestros paquetes, además de conocer aquellos que se nos son enviados.

Autenticación y Seguridad

```
(msosa-kali@msosa-kali)-[~]
$ sudo passwd
Nueva contraseña:
Vuelva a escribir la nueva contraseña:
passwd: contraseña actualizada correctamente

(msosa-kali@msosa-kali)-[~]
$ cat /etc/login.defs
#
# /etc/login.defs - Configuration control definitions for the shadow packag
# e.
#
# REQUIRED for useradd/userdel/usermod
#   Directory where mailboxes reside, _or_ name of file, relative to the
#   home directory.  If you _do_ define MAIL_DIR and MAIL_FILE,
#   MAIL_DIR takes precedence.
#
#   Essentially:
#   - MAIL_DIR defines the location of users mail spool files
#     (for mbox use) by appending the username to MAIL_DIR as defined
#     below.
#   - MAIL_FILE defines the location of the users mail spool files as th
# e
#   fully-qualified filename obtained by prepending the user home
#   directory before $MAIL_FILE
#
# NOTE: This is no more used for setting up users MAIL environment variable
#       which is, starting from shadow 4.0.12-1 in Debian, entirely the
#       job of the pam_mail PAM modules
#       See default PAM configuration files provided for
#       login, su, etc.
#
# This is a temporary situation: setting these variables will soon
# move to /etc/default/useradd and the variables will then be
# no more supported
MAIL_DIR      /var/mail
MAIL_FILE     .mail
```

Figure 7: Políticas de Seguridad y Autenticación

Es posible además configurar aquellas políticas de seguridad y autenticación de usuarios dentro del dispositivo para que no sean vulnerables y la información sea accesible de forma controlada.

Ejemplos

Política de Contraseñas

```
msosa-kali@msosa-kali: ~
Session Acciones Editar Vista Ayuda
GNU nano 8.7.1 /etc/login.defs *
#
PASS_MAX_DAYS 30
PASS_MIN_DAYS 2
PASS_WARN_AGE 7
```

Figure 8: Configuración de Archivo de Credenciales

En la figura 8 se puede apreciar la modificación del archivo `/etc/login.defs` para cambiar cada cuánto se debe actualizar las contraseñas, además de otras configuraciones importantes.

En la figura 9 se observa la ejecución y nueva información de la contraseña que se generó para un nuevo usuario.

```
msosa-kali@msosa-kali: ~  
Session Acciones Editar Vista Ayuda  
(msosa-kali@msosa-kali)-[~]  
$ sudo nano /etc/login.defs  
(msosa-kali@msosa-kali)-[~]  
$ sudo adduser estudiante1  
Nueva contraseña:  
Vuelva a escribir la nueva contraseña:  
passwd: contraseña actualizada correctamente  
Cambiando la información de usuario para estudiante1  
Introduzca el nuevo valor, o pulse INTRO para usar el valor predeterminado  
Nombre completo []: Estudiante  
Número de habitación []: 0  
Teléfono del trabajo []: 0  
Teléfono de casa []: 0  
Otro []:  
Is the information correct? [Y/n] Y  
(msosa-kali@msosa-kali)-[~]  
$ sudo passwd estudiante1  
Nueva contraseña:  
Vuelva a escribir la nueva contraseña:  
passwd: contraseña actualizada correctamente  
(msosa-kali@msosa-kali)-[~]  
$ sudo chage -l estudiante1  
Último cambio de contraseña : abr 30, 2026  
026  
La contraseña caduca : may 30, 2026  
Contraseña inactiva : nunca  
La cuenta caduca : nunca  
Número de días mínimo entre cambio de contraseña : 2  
Número de días máximo entre cambio de contraseña : 30  
Número de días de aviso antes de que caduque la contraseña : 7  
(msosa-kali@msosa-kali)-[~]
```

Figure 9: Comprobación de Nueva Configuración de Contraseñas

Política de Complejidad de Contraseñas

```
(msosa-kali@msosa-kali)-[~]  
$ sudo nano /etc/pam.d/common-password  
(msosa-kali@msosa-kali)-[~]  
$ sudo passwd estudiante1  
Nueva contraseña:  
Vuelva a escribir la nueva contraseña:  
passwd: contraseña actualizada correctamente
```

Figure 10: Configuración de Archivo para Contraseñas Seguras

Al editar el archivo `/etc/pam.d/common-password` se puede exigir una contraseña con mayúsculas, números y longitud mínima, además de símbolos y ciertos requisitos para una contraseña mucho más segura.

Conclusiones

- La seguridad requiere múltiples controles coordinados

- Kali Linux evidencia vulnerabilidades fácilmente explotables
- Ubuntu demuestra la importancia del monitoreo y control
- NIST proporciona una base sólida de seguridad
- El monitoreo continuo es clave para detectar amenazas
- La seguridad es un proceso dinámico que requiere mejora constante